Protecting Personal Identifiable Information in the Financial Services Sector with Zero Trust Architecture

by Jackson Munuo

B.S. in Information Systems and Accounting, May 1999, Calumet College of St. Joseph
M.B.A in Technology Management and Administrative Studies, May 2008, Indiana University

A Praxis submitted to

The Faculty of
The School of Engineering and Applied Science
of The George Washington University
in partial fulfillment of the requirements
for the degree of Doctor of Engineering

January 2024

Praxis directed by

Mehdi Hashemipour
Professorial Lecturer of Engineering and Applied Science

The School of Engineering and Applied Science of The George Washington University certifies that John Howard Doe has passed the Final Examination for the degree of Doctor of Engineering as of December 01, 2023. This is the final and approved form of the Praxis.

Protecting Personal Identifiable Information in the Financial Services Sector with Zero Trust Architecture

Jackson Munuo

Praxis Research Committee:

Mehdi Hashemipour, Professorial Lecturer of Engineering and Applied Science, Praxis Director

John Sahlin, Professorial Lecturer in Engineering and Applied Science, Committee Member

Muhammad Islam, Professorial Lecturer in Engineering and Applied Science, Committee Member

© Copyright 2023 by Jackson Munuo
All rights reserved

Dedication

The author would like to dedicate this praxis to his wife, Dr. Charmaine Mziray-Andrew, MD; his children, Jackson Jr., aka JJ and Joyce; his parents (the late) Abraham N. Munuo and Raheli Munuo; his siblings, John, James, and Josephine; his nephews and nieces who inspired, motivated, and supported him throughout his doctoral program. Furthermore, this dedication extends to Reverend Dr. Bassam and Katie Abdallah, his pastor and wife, as well as his uncle Wilfred A. Makere. These remarkable individuals have been a constant source of inspiration and unwavering support throughout his academic and professional endeavors. Their steadfast encouragement, particularly during challenging moments, has truly been a blessing; without their guidance and support, none of these accomplishments would have been attainable. Here's to their exceptional contributions!

Acknowledgments

I would like to express my gratitude to my principal advisor, Dr. Mehdi Hashemipour, for his invaluable feedback and guidance throughout this process. Additionally, I would like to thank Dr. John Sahlin for his exceptional teaching style that has inspired me to delve deeper into the concepts of Zero Trust Architecture, which ultimately sparked my interest in this research topic. Finally, a special thanks goes out to Dr. Muhammad Islam, the esteemed chair of the praxis committee, for his leadership and guidance during our committee meeting.

The author would like to express gratitude towards the new friends at ColorTokens who played a crucial role in dedicating their personal time and providing technical support to ensure that the system used for this research was appropriately configured according to the research objectives. Without their dedication, sacrifices, and expertise, this research would not have been successful. Special thanks are extended to Michael Mastrole, Katie Benson, and Venky Raju, CISSP, CCSP, for their invaluable contributions.

The author wishes to acknowledge his colleagues at CNA Insurance, JP Morgan Chase, Protiviti, Heidrick & Struggles, and Horace Mann Educators Corporation, who shaped his intellectual curiosity over the years and whose support in his career was very influential to his success in various roles in these organizations.

The author also wishes to acknowledge his relatives and friends who, in one way or another, have also been part of this journey. He is grateful beyond words for every support and encouragement received along the way. Without such support, this academic journey would not have been possible.

Abstract of Praxis

Protecting Personal Identifiable Information in the Financial Services Sector with Zero Trust Architecture

The financial services sector collects and processes personally identifiable information (PII) such as names, social security numbers, bank accounts, and credit card numbers. This sector is a major target for data breaches and ransomware attacks due to its handling of PII, use of cloud-based technologies, and remote work. Cybercriminals are attracted to the potential financial gains from successful attacks in this industry (Adrian & Ferreira, 2023).

Traditional perimeter security is no longer effective in protecting the financial services sector against data breaches and ransomware. The constant evolution of threats requires organizations to adapt. The rise in these incidents highlights the need for better protection measures. Zero Trust Architecture (ZTA) offers solutions to address cyber challenges in the industry and can enhance the protection of PII data for financial institutions.

Zero Trust is a new approach to security that focuses on users, devices, and applications rather than network perimeters. It assumes no inherent trust based on location or ownership and instead requires authentication and authorization for all access. This strategy relies on behavioral analytics and continuous authentication to establish trust (Rose et al., 2020).

This study has shown that ZTA is a superior cybersecurity approach for safeguarding sensitive data within the contemporary corporate network. Additionally, it suggests enhancing the detection capabilities by integrating the anomaly detection function into the threat intelligence component.

Table of Contents

Dedication ..... **iv**

Acknowledgments ..... **v**

Abstract of Praxis ..... **vi**

List of Tables ..... **xiv**

List of Symbols ..... **xv**

List of Acronyms ..... **xvi**

Chapter 1. Introduction **1**

1.1 Background 1

1.2 Research Motivation 2

1.3 Problem Statement 3

1.4 Thesis Statement 5

1.5 Research Objectives 6

1.6 Research Questions and Hypotheses 7

1.7 Scope of Research 7

1.8 Research Limitations 8

1.9 Organization of Praxis 8

Chapter 2. Literature Review **10**

2.1 Introduction 10

2.2 The Evolution of Information Security 11

2.3 Perimeter Security Architecture 13

2.4 The Gap between Perimeter Security and Modern Corporate Network Environment 14

2.5 Zero Trust Architecture....19
2.6 The Zero Trust Architecture Security Pillars....21
2.7 ZTA Logical Components....24
2.8 Summary and Conclusion....28
Chapter 3. Methodology....30
3.1 Overview....30
3.2 Reference Architecture....30
3.3 Tenets of Zero Trust....33
3.4 Reference Architecture (RA) Principles....34
3.5 Micro-segmentation....37
3.6 Setting up the 3-tier Application Infrastructure for the Praxis:....41
3.7 Proposed Machine Learning Model....43
3.8 Proposed Threat Intelligence Enhancement....46
3.9 Evaluation of the Proposed Hypotheses....47
3.10 Data Preparation....52
3.11 Data Preprocessing....53
3.11.1 Feature Creation....55
3.11.2 Split Data....55
3.11.3 Model Selection....56
3.11.4 Model Training....56
3.11.5 Model Evaluation....56
3.11.6 Tuning and Optimization....56

3.12 Logistic Regression....57
3.13 Random Forest....58
3.14 XGBoost....59
3.15 Time Series Data Analysis....59
3.15.1 Data Collection....60
3.15.2 Data Preprocessing....60
3.15.3 Visualization....60
3.15.4 Decomposition....60
3.15.5 Stationarity....61
3.15.6 Model Selection....61
3.15.7 Model Training....61
3.15.8 Model Evaluation....61
3.15.9 Forecasting....61
3.15.10 Model Validation....62
3.15.11 Visualization of Forecasts....62
3.15.12 Interpretation....62
3.15.13 Decision-Making....62
3.16 Handling Imbalanced Data....62
3.17 Near Miss Under-sampling....64
3.18 The Two-Sample Z-Test....64
3.19 Model Validation Process....65

3.20 SHAP (Shapley Additive exPlanations) 67

Chapter 4. Results 69

4.1 Introduction 69

4.2 Feature Engineering on Simulated Attacks Data 70

4.3 Simulation Attacks Results Analysis 72

4.4 Time Series Analysis 72

4.5 Conclusion 76

4.6 Request Analysis 76

4.7 Additional Observation 78

4.8 Conclusion 79

4.9 TCP Flags Analysis 79

4.10 Source and Destination Analysis 82

4.11 Window Size and Length Analysis 83

4.12 HTTP Status Code 85

4.13 Anomaly Detection Model 87

4.14 SHAP (Shapley Additive exPlanations) 93

4.15 Summary 95

Chapter 5. Discussion and Conclusions 97

5.1 Discussion 97

5.2 Conclusions 98

5.3 Contributions to Body of Knowledge 100

5.4 Recommendations for Future Research 101

Appendix A 110

List of Figures

Figure 1. Canam Research 3

Figure 2. Data Breaches Incidents 4

Figure 3. Core Zero Trust Logical Components 6

Figure 4. Model for Defense in Depth 14

Figure 5. Firewall Implementation 16

Figure 6. Advantages and Disadvantages of Perimeter Security 19

Figure 7. Zero Trust Security 21

Figure 8. Data Plane 22

Figure 9. Perimeter Security vs. ZTA 24

Figure 10. Trust Algorithm Input 27

Figure 11. Core ZTA Components 33

Figure 12. ZT Access Flow 35

Figure 13. ZT Design Pattern 37

Figure 14. ZTA Centralized Orchestration & Policy Management 38

Figure 15. Policy Deployment for a Three-tier Application 40

Figure 16. Praxis Application Architecture 42

Figure 17. ZTA Based Application 42

Figure 18. Perimeter Security Based Application 43

Figure 19. Proposed Model 44

Figure 20. Praxis Database 48

Figure 21. Nmap Scanning of Perimeter Based System 49

Figure 22. Scanner Dashboard 50

Figure 23. Perimeter Based Security Vulnerability Scan Results..... 50
Figure 24. ZTA-Based Environment Vulnerability Scan Results 51
Figure 25. Model Evaluation 56
Figure 26. Logistic Regression Algorithm..... 57
Figure 27. Random Forest Algorithm..... 58
Figure 28. XGBoost Algorithm 59
Figure 29. Binary Confusion Matrix..... 66
Figure 30. Performance Evaluation Measures..... 67
Figure 31. Logs from the Simulated Systems Attacks..... 70
Figure 32. Network Traffic Raw Data 71
Figure 33. ZTA Based System with Policy Running..... 72
Figure 34. ZTA Server Image..... 73
Figure 35. ZTA Policy Enforcement 73
Figure 36. Perimeter-Based Security System 74
Figure 37. Perimeter Security System 75
Figure 38. Response Methods for Perimeter Security Based System..... 77
Figure 39. ZTA Response Methods for Security Based System 77
Figure 40: Policy Management Dashboard..... 78
Figure 41.CHi-Squared Test 81
Figure 42. Flags Distributions Between the Two Systems..... 81
Figure 43.Chi-Squared Test..... 82
Figure 44. Box Plot Analysis of Window and Length of Packages on Perimeter System..... 83

Figure 45. Box Plot Analysis Window and Length pf Packages on ZTA System Logs..... 83
Figure 46. Z-Test Two Sample Analysis..... 84
Figure 47. HTTP Status Code Analysis..... 85
Figure 48. Communication Sequence Analysis..... 85
Figure 49.SHAP Analysis for Perimeter Based System..... 93
Figure 50. SHAP Analysis for ZTA Based System..... 94

List of Tables

Table 1. Data Dictionary of Research Data Source 53

Table 2. Simulated Attacks Categories 54

Table 3. Event Codes 54

Table 4. HTTP Methods 55

Table 5. TCP Flags Table 80

Table 6. Logistic Regression Anomaly Detection Model Evaluation Confusion Matrix for Perimeter-Based System 88

Table 7. Logistic Regression Anomaly Detection Model Evaluation Confusion Matrix for ZTA-Based System 89

Table 8. Random Forest Model Evaluation Confusion Matrix for Perimeter-Based System 90

Table 9. Random Forest Model Evaluation Confusion Matrix for ZTA-Based System 90

Table 10. XGBoost Model Evaluation Confusion Matrix for Perimeter-Based System 91

Table 11. XGBost Model Evaluation Confusion Matrix for ZTA-Based System 92

Table 12. Models Performance Summary 99

List of Symbols

x	State of the system
y	Output of the system
z	Noise
$\leq$	Less than

List of Acronyms

ABAC	Attribute- Based Access Control
API	Application Programming Interface
BYOD	Bring Your Own Device
CDM	Continuous Diagnostics and Mitigation
DHS	Department of Homeland Security
DoD	Department of Defense
IAM	Identity and Access Management
IoT	Internet of Things
MFA	Multi-factor Authentication
NIST	National Institute of Standards and Technology
PA	Policy Administrator
PAM	Privilege Access Management
PDP	Policy Decision Point
PE	Policy Engine
PEP	Policy Enforcement Point
PII	Personally Identifiable Information
PKI	Public Key Infrastructure
SDDC	Software Designed Defined Data Center
SDN	Software Defined Network
SDP	Software-defined Perimeter
SIEM	Security Information and Event Monitoring
SSO	Single Sign-On

TIC	Trusted Internet Connections
U.S.	United States
UEBA	User and Entity Behavior Analytics
VPN	Virtual Private Network
ZTA	Zero Trust Architecture
ZTNA	Zero Trust Network Access

Chapter 1. Introduction

1.1 Background

Cyberattacks in the financial sector and costs associated with data breach recovery are increasing. As an industry, financial service companies are increasingly transitioning to digital solutions. These companies are reimagining products and services around customer centricity to develop new business models to meet customer needs. The transition to cloud solutions allows the industry to lower operational costs and scale their utilization based on computing demands, flexibility to access applications, and reliability due to better resilience solution offerings, and businesses can access the latest technology without investing in it themselves. During the novel COVID-19 pandemic, many companies in the industry quickly transitioned to cloud solutions to enable remote work during the pandemic.

This shift to digital and cloud solutions coincided with the unprecedented number of data breaches and ransomware, mainly because of remote connectivity, as most companies asked their employees to work from home. The rise of the Bring Your Own Device (BYOD) policy and the COVID-19 pandemic that led to remote working have become common issues for many companies (Teerakanok et al., 2021).

The financial services sector is second only to healthcare in terms of the cost of cyberattacks. By 2022, the average price for a breach in the industry was $4.82 million. Driving the high cost of data breaches includes slow adaptation of new cybersecurity tools and regulatory compliance fines after a breach (Eddolls, 2022).

Ransomware is a malicious software that encrypts and blocks a victim's access to their data until a ransom is paid. While ransomware incidents are not as common as

phishing, they have been more prevalent in the financial services industry because, once successful, attackers would not release the data until they were paid to do so. Financial service companies can afford to pay these large ransoms; hence, the industry is a major target of these attacks.

Traditional ransomware techniques encrypt target data and charge victims a decryption key fee. The cybercriminals employ a double-extortion scheme, wherein they threaten to release or sell the data if the ransom is not paid (Chauhan and Kshetri, 2023).

1.2 Research Motivation

My interest in this topic stems from 20 years of work experience in the financial services sector and awareness of the increased reported data breaches and ransomware events, partly due to the changing landscape in technology, regulatory compliance, and data protection requirements that insist on the disclosure of cyber incidents. In addition, the recent shift to a greater acceptance of remote work because of the threat of COVID-19 has also led to an increased number of cybersecurity incidents. The pandemic has accelerated the process of digital transformation, resulting in the adoption of online financial services, advancement in payment systems, a surge in the utilization of cloud services, big data, and the Internet of Things (IoT), and advances in cyber-attacks (Bajracharya et al., 2023).

According to a report by the Federal Trade Commission, fraudulent activities resulted in a loss of $5.8 billion for consumers in 2021. This marked an alarming 70% increase compared to the previous year - 2020 (Bajracharya et al., 2023).

After the pandemic, approximately 74% of businesses in America have continued to allow their employees to work remotely or on a hybrid basis due to changing needs of

employees seeking more flexibility and balance between their personal and professional lives. The increase in data breaches and ransomware events coincided with these changes, necessitating the need for a better cybersecurity framework. The Zero Trust Architecture (ZTA) offers solutions that may address the industry's cyber challenges. This model can enhance protection measures to safeguard PII data and address regulatory compliance requirements at a reasonable cost. Clearly, the current cybersecurity framework based on perimeter security is no longer effective in successfully protecting businesses and customers alike.

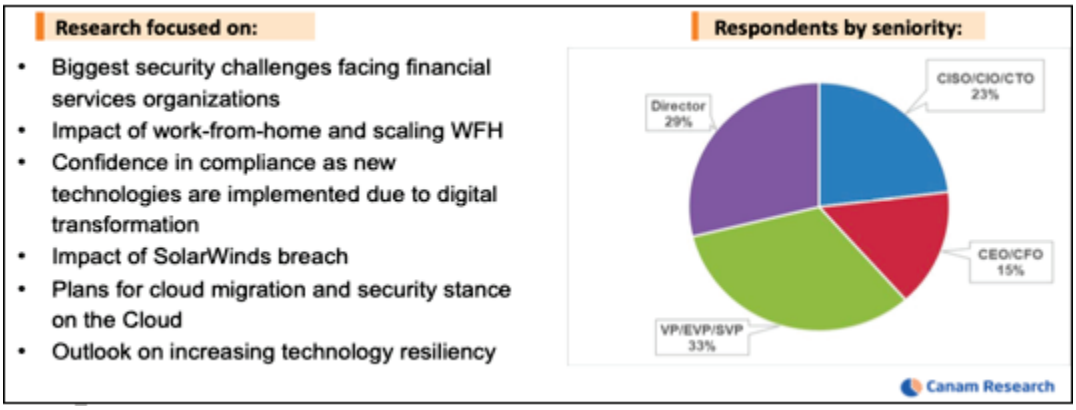


Figure 1. Canam Research

According to the research conducted by Canam Research (2021) (Figure 1), endpoint and cloud security were identified as major issues to employees' work from home. The respondents mentioned that traditional security was difficult to scale and support work-from-home employees.

1.3 Problem Statement

As a critical infrastructure, the financial services sector is increasingly a primary target for successful data breaches and ransomware attacks (Figure 2). The collection of a significant amount of personally identifiable information (PII), a shift to cloud-based

solutions, and remote connectivity by employees and vendors increase the attack surface under perimeter-based security. The traditional cyber security model based on the perimeter security strategy has proven inadequate to safeguard PII data. Therefore, I propose a new threat detection model for this critical infrastructure. “In 2022, the global number of stolen consumer data exceeded 254 million. The Maine attorney general revealed that in the U.S. alone, approximately 9.4 million consumers across the country were impacted by data theft targeting financial companies” (Flashpoint, 2022).

Compromises by Industry: Q4 2022/2022 YTD vs. Full Years 2021 & 2020

	Q4 2022		2022 YTD		2021		2020	
	Compromises	Victims	Compromises	Victims	Compromises	Victims	Compromises	Victims
Education	35	695,961	100	1,745,226	125	1,687,192	42	974,054
Financial Services	75	1,628,050	268	27,146,354	279	19,978,108	138	2,687,084
Government	22	717,793	74	1,739,462	66	3,244,455	47	1,100,526
Healthcare	89	9,429,886	344	26,259,933	330	30,853,767	306	9,700,238
Hospitality	13	131,181	34	69,235,147	33	238,445	17	22,365,384
Manufacturing & Utilities	70	341,430	249	23,897,836	222	49,782,583	70	2,896,627
Non-Profit/NGO	20	265,389	71	980,021	86	2,339,646	31	37,528
Professional Services	60	1,304,938	224	6,248,711	184	22,729,391	144	73,012,145
Retail	15	102,870	65	792,195	102	7,212,912	53	10,710,681
Technology	34	229,840,738	86	248,564,988	79	44,684,180	67	142,134,883
Transportation	11	630,817	36	3,991,847	44	569,684	21	1,208,292
Other	68	7,239,325	251	11,541,592	308	79,660,479	172	43,391,302
Unknown	–	–	–	–	4	35,232,664	–	–
Totals	**512**	**252,328,378**	**1,802**	**422,143,312**	**1,862**	**298,213,506**	**1,108**	**310,218,744**

Figure 2. Data Breaches Incidents

Source: (ITRC, 2022)

According to the 2022 IBM Security and Ponemon Institute Report, the average cost of a data breach was $4.82 million. Of these attacks, 28% were either ransomware or destructive attacks.

According to the Identity Theft Resource Center, the trend in the number of breach notices dropped by 50%. This does not imply that the number of incidents is decreasing

or that companies are getting better at protecting their data assets and systems; rather, it highlights the lack of required standards across all 50 states in the United States mandating public notice filing of cybersecurity breaches. While some states require such public notice, others do not. Federal law is required for reporting consistency.

1.4 Thesis Statement

The rise in the number of people working from home and the shift towards cloud-based solutions have made it necessary to adopt a fresh approach to cybersecurity in order to effectively safeguard personally identifiable information (PII) data.

This research focuses on the Threat Intelligence component, which provides information to the policy engine for making access decisions. It gathers data from internal and external sources and shares information on attacks and vulnerabilities (Rose et al., 2020). The Threat Intelligence component is crucial in the Zero Trust Architecture (ZTA) concept as it drives automated security technologies in the defense environment. By monitoring network traffic, it enhances security by quarantining and eliminating threats. Maintaining a responsive system is important for continuous trust evaluation and access control.

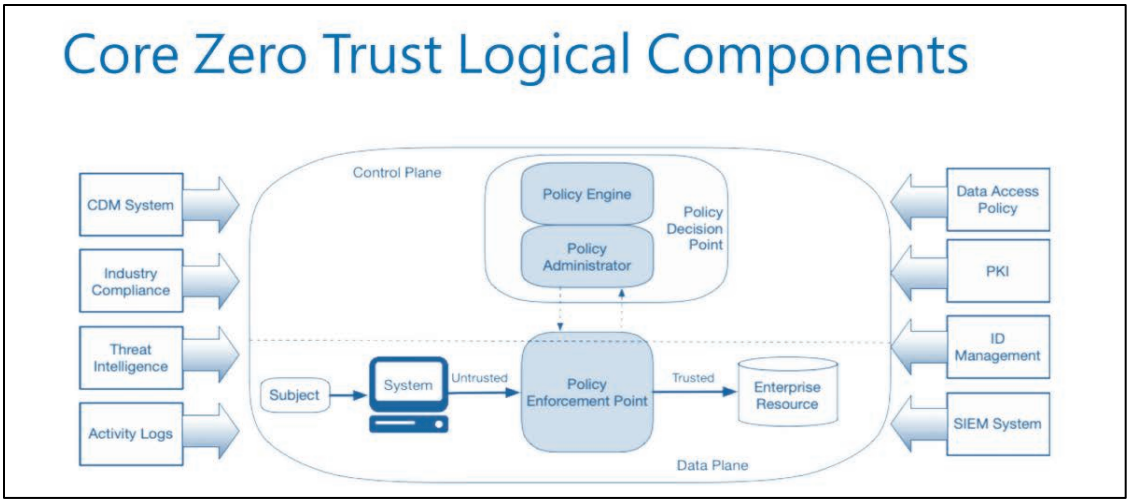


Figure 3. Core Zero Trust Logical Components

The ZTA framework significantly improves data protection controls by introducing several controls that play a crucial role in enhancing the protection of network assets, as depicted in Figure 3.

ZTA has several components that are covered in detail in subsequent chapters. All these components work together to protect network assets and prevent unauthorized access and lateral movements.

1.5 Research Objectives

The research objectives were the following:

- To analyze how the financial services sector can enhance its security measures and effectively protect PII data against cyber-attacks.
- To investigate whether the reliance on the perimeter security approach to protect cloud workloads and remote connectivity leads to data breaches and ransomware.
- To analyze whether the use of ZTA offers better protection measures for modern enterprises and helps improve security posture.

- To evaluate the effectiveness of ZTA against novel attacks.
- To improve ZTA threat intelligence capabilities by introducing anomaly detection features.

1.6 Research Questions and Hypotheses

The focus of this study is to enhance data security in the contemporary corporate network environment by strengthening threat intelligence capabilities through detective modeling. This research is guided by the following research questions:

RQ1: Can the Financial Services sector rely on the perimeter security model to protect PII data?

RQ2: Is ZTA a more effective security model for protecting PII?

RQ3: Can ZTA's threat Intelligence capabilities be improved with the addition of anomaly detection features?

In the review of other studies, these research questions were not part of those studies.

The three hypotheses that relate to examining the research questions are as follows:

H1: The perimeter security model is less effective at preventing cyber threats to cloud workloads and remote connectivity.

H2: The ZTA security model protects PII data more effectively than perimeter-based security.

H3: Adding anomaly detection features improves ZTA detection capabilities.

1.7 Scope of Research

The scope of this research aims to address the problem statement by looking at existing cybersecurity defense strategies and comparing their effectiveness against some

of the emerging concepts within the cybersecurity community. The perimeter security concept has faced challenges due to the shifting technology landscape that led to cloud solutions.

1.8 Research Limitations

This praxis provides an anomaly detection model that is used in real-time to detect potential malicious activities or attacks in the ZTA network environment. The model helps monitor traffic from users, devices, and applications into and inside the network and between different micro-segmented areas of the network for any signs of deviation from normal operating conditions that may imply a potential attack. Its primary objective is to eliminate data breaches and ransomware. This research is limited to the availability of validation data as most companies that have already implemented ZTA have yet to publish network traffic data to the public for research purposes. The praxis exclusively analyzes data from a ZTA micro-segmentation sandbox environment configured to test ZTA use cases.

In order to obtain precise predictions, it is necessary to update the machine learning model regularly. This will ensure that any changes in the threat landscape and security technologies do not negatively affect the outcome.

1.9 Organization of Praxis

The praxis is organized into five chapters. Chapter 1 provides the background information required to understand the research topic, motivation, problem and thesis statement, objectives, questions, and hypotheses. Chapter 2 provides a detailed review and summary of the literature related to remote connectivity, data breaches, ransomware, ZTA, Perimeter security, gaps in the threat intelligence component within ZTA, and

relevant research. Chapter 3 describes data sources, data acquisition methods, data engineering, research methodologies, and analytical techniques used in the praxis. Chapter 4 presents the research findings and their implications for reducing data breaches and ransomware. Chapter 5 summarizes findings, inferences, conclusions, and improvements to the current cybersecurity model and recommendations for future work.

Chapter 2. Literature Review

2.1 Introduction

The scope of the praxis, as mentioned in Chapter 1, is focused on preventing ransomware and data breaches in the financial services sector in the age of cloud computing, mobile devices, and hybrid workforce following the novel 2021 COVID-19 pandemic.

Chapter 2 begins with an overview of the traditional perimeter-based security model and the weaknesses of this security model in the current working and technological environment. The financial services sector's reliance on this security model in the times of hybrid workers and remote connectivity has led to increased data breaches and ransomware, causing significant operational, financial, and cybersecurity risks.

The chapter explores the challenges that are invariably associated with the perimeter-based security model and emphasizes the need to transition towards the ZTA security model in order to safeguard PII data in today's corporate network environment effectively.

The chapter then introduces ZTA as an alternative to perimeter security. This approach offers more cyber resilience to businesses of all types and sizes than the traditional perimeter security approach. In addition, the chapter provides additional details on the features of ZTA concepts, its tenets, its threat intelligence capabilities, gaps, and how to improve it, which is the focus of this praxis.

Based on research conducted in 2019, it was found that the financial sector accounted for 61.7% of all leaked records. Further analysis reveals that approximately 75% of breaches

were caused by malware and hacking, while accidental disclosures contributed to around 18% of the breaches (Akhtar et al., 2021).

2.2 The Evolution of Information Security

Before the internet was discovered, systems security primarily focused on physical security controls that manage access to data centers and corporate buildings. Within these buildings, the security systems depended on the fact that only a few individuals comprehended the complex structure and operational mechanics of the resources on the Local Area Network (LAN). This practice, referred to as security through obscurity, proved effective in environments lacking external communication connections (Department of Energy, 2006). As a result, companies heavily relied on physical security controls to safeguard their systems and sensitive information.

However, with the arrival of the internet and advancements in networking technology, the world became more interconnected. Companies started collecting vast amounts of personal, commercial, military, and government information on worldwide networking infrastructures. Because of the rising reliance on networked systems and the ease with which intellectual property can be accessed via the internet, network security has become critical.

The discovery of the internet allowed for information sharing within corporate networks as well as with business partners and customers outside. This led to significant developments in electronic services and products. Companies like Yahoo, Amazon, and Google emerged during this period and played a vital role in driving information sharing through e-commerce.

In the 1970s through mid-80s, cybersecurity was not a major concern for most companies, people, or governments. All that changed with the Morris Worm incident in 1988, which infected computers across various networks worldwide within a short period of time. Prior to that, cybersecurity incidents were rare (Orman, 2003). This incident exposed vulnerabilities that can be found in networked systems and underlined the need for effective security controls. As more people started using the internet, leading to the dot-com era, companies and governments recognized that information was a valuable strategic resource. Consequently, cyber-related incidents also increased rapidly. As a result, companies began treating information security as an enterprise risk and implemented data protection measures to mitigate this risk.

The structure of the internet created numerous vulnerabilities for potential security threats. To effectively address these concerns, businesses adopted antivirus software, firewalls, and encryption mechanisms as protective measures for corporate and customer data during transmission and storage. This was a shift from reliance on basic security practices such as username and password. The idea was to add layers of security controls that make it difficult for external threats to penetrate the network.

Moreover, social engineering techniques like phishing emerged as popular methods employed by hackers to trick unsuspecting users into willingly disclosing sensitive information. These developments necessitated a shift from traditional security practices to more holistic approaches involving user education and awareness. We will cover two main approaches that have revolutionized cybersecurity practices and have tried to keep up with hacking techniques that are constantly evolving to cause cybersecurity havoc to users, companies, and governments.

2.3 Perimeter Security Architecture

The traditional perimeter/defense-in-depth security model has existed since the early days of computing, starting with mainframe computers. During those days, security was designed to protect the physical hardware from unauthorized access by using physical barriers, guards, and access control lists.

With the growth of computing technology and the emergence of interconnected networks, the emphasis on perimeter security shifted towards safeguarding the network perimeter using firewalls, intrusion detection systems, and other network security devices. This was done to effectively protect information assets.

The concept of defense in depth originates from the military, where this defensive strategy is employed by incorporating multiple and diverse defense measures to hinder the successful infiltration of attacks through various layers of defense (Alsaqour et al., 2021).

In the corporate network environment, this concept is employed to establish multiple layers of security and defense measures (Figure 4). Its purpose is to hinder attackers from unauthorized access or engaging in compromising activities that may jeopardize the organization's resources, network, and assets. Adding multiple layers enhances the effectiveness of protecting an organization's hardware, software, network, computing devices, and assets. This approach overcomes potential vulnerabilities and shortcuts that may arise from relying on a single layer of defense. In comparison to organizations with only one layer of defense, those implementing different security layers and defenses are more challenging for attackers to target and breach (Alsaqour et al., 2021).



- **Policies & procedures for security** – guides acceptable usage of the system.
- **Physical security** – protects enterprise assets from physical damages or safety.
  - **Network security** – allows or blocks incoming or ongoing packets traffic using firewalls, Intrusion Detection Prevention systems (IDSPS).
- **Monitoring and logging event** – tracks all network activities to eliminate potential threat.
- **Host security** – provides security for workstations.
- **Session security** – prevents an attacker from hijacking the session between the client and the server.
- **Application security** – secures application with access control lists, authentication and authorization mechanism, vulnerabilities elimination, security assessment, etc.
- **Data security** – secure data in transit, during processing and in storage.

Figure 4. Model for Defense in Depth

2.4 The Gap between Perimeter Security and Modern Corporate Network Environment

The growing usage of mobile devices and cloud solutions, even after the pandemic, poses significant risks to corporate data and applications. This is especially true as remote workers continue to access them. In such an environment, network-based perimeter security is no longer an adequate strategy for protecting information assets in modern computing environments. Data breaches and ransomware risk constantly increase, requiring a new cybersecurity defense approach (Rose et al., 2020).

This approach to network design involves securing or leaving unsecured both the physical and virtual services of the network, depending on business needs. However, this method becomes ineffective in modern cloud computing and ad-hoc endpoint device environments. In these environments, the composition of the network and available resources changes dynamically, rendering the DMZ (Demilitarized Zone) obsolete.

Traditional networks rely on verifying user and application identities using unique parameters such as MAC addresses, IP addresses, group policies, and access privileges. However, attackers with moderate network knowledge can easily spoof and modify these unique parameters at their convenience. This vulnerability was highlighted by a NIST report in 2013 (Sarkar et al., 2022).

The modern corporate networks are characterized by the following:

- **Agility**: Modern networks should be able to adapt to quick changes in user demand, device proliferation, and application requirements. This requires a flexible architecture that can easily be scaled up and down as needed. Usually, applications are distributed across corporate data centers and clouds.
- **Scalability**: Modern networks must be able to support an increasing number of users, devices, and applications. This requires a network infrastructure that can be easily expanded without impacting performance. Such scalability can create an attack surface that is larger than a traditional perimeter-controlled enterprise.
- **Security**: Modern networks must be secure. Given the digital transformation taking place today and the ever-increasing attack surface, proper protection of sensitive data must be undertaken in modern networks. Users' mobility adds to the complexity of effectively protecting endpoints.

Traditional perimeter security, its functioning, and the difficulties in meeting contemporary security requirements are examined in greater detail. Perimeter security

employs a firewall to safeguard an organization's private network from public networks like the internet. The perimeter firewall thoroughly assesses incoming and outgoing packets within the private network, allowing or denying them according to pre-established rules. Access control lists (ACLs) are used to establish rules that define permitted network names, Internet Protocol (IP) addresses, and port numbers. These rules can be configured to manage inbound and outbound traffic, as shown below in Figure 5.

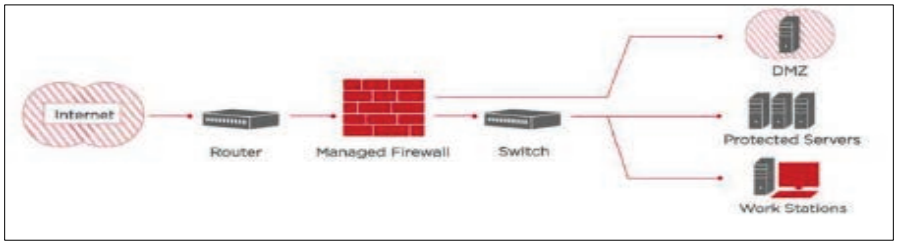


Figure 5. Firewall Implementation

Some perimeter security architecture implementations utilize firewalls placed throughout the network to enforce security policies at various points beyond just the internet access gateway. However, this approach lacks authentication information on packets, forcing the network firewall to make access control decisions based solely on the source IP address of the packet or by establishing a new roadblock and requiring user authentication for that specific firewall.

Figure 5 illustrates the typical layout of a corporate network following a perimeter-based security architecture. Once an attacker gains access to the network, it becomes easier for them to move laterally and compromise other systems within it. There is no additional authentication required once initial access is deemed appropriate.

In addition to firewalls, there are other components that support and provide supplementary protection for the perimeter network, such as:

- **Routers** – A router directs inbound and outbound traffic in the network.

- **Intrusion Detection System (IDS)** – monitors a network for suspicious events and issues security alerts.
- **Intrusion Prevention System (IPS)** - Like IDS, it also monitors the network for malicious activity. However, IPS can automatically defend the target, unlike IDS, which is passive in its monitoring.
- **Demilitarized Zones (DMZ)** – Any subnet between the enterprise's network and public networks. It enables organizations to connect to untrusted public networks while protecting their internal networks.

The Problem with the Legacy Security Models

In perimeter-based security, a user's identity is verified when connecting to a network. If the network has a single sign-on (SSO), the cached credentials are validated by the application that requires authentication from the user. There is no additional validation check conducted on individual applications or data, and there is also no subsequent evaluation of whether the user's access, determined by their identity and real-time threat intelligence signals, remains appropriate.

There are several challenges associated with perimeter-based security architecture. These include managing multiple security solutions, dealing with threats from privileged users, and controlling access for businesses that rely on both cloud and on-premises environments. The authentication and authorization of endpoints in the environment are inconsistently implemented and may not always consider device hygiene. For example, if a mobile employee connects their laptop to the internet via a mobile hotspot and their machine becomes infected with a virus, they could bring that

virus into the corporate network when they return to the office because subsequent connections do not require checking the device's security posture.

Perimeter-based security architecture also does not provide a comprehensive approach to security, as shown in Figure 5. It allows for lateral movement within the network regardless of an individual's role within the organization, giving users more access than necessary for their job function. This increases the risk of inside threats and unauthorized access to sensitive data for malicious actors who enter the network. In contrast, Zero Trust (ZT) concepts and principles impact each scenario by providing centralized, standardized, and integrated controls to mitigate these security challenges and risks (Rose et al., 2020).

Finally, the perimeter security architecture is built upon the belief that most threats originate from external sources. Keeping this concept in mind, the security design implemented in this model incorporates IPS/IDS/Firewalls as a means of thwarting external attacks. However, it is important to note that a significant portion of network traffic occurs between servers, which may go unnoticed within this security framework. Consequently, any threats already present within the network can move laterally and remain undetected by security teams for an extended period.

In recent years, the corporate network environment has gotten more complex and continues to evolve further, contributed to by the introduction of cloud computing and mobile devices, which has made the traditional perimeter cybersecurity strategy inadequate for protecting corporate networks against nation-states or well-equipped adversaries and insider threats. Modern networks must possess agility, scalability, and security to effectively cater to the needs of today's businesses.

This praxis will also focus on Threat Intelligence and Policy Enforcement components and how together they work to protect the network environments better than perimeter-based security architecture. Micro-segmentation can help reduce risks like lateral movement in a perimeter-based environment. However, detecting insider threats is challenging since insiders typically already have granted access, which may limit the effectiveness of identity or endpoint-specific controls.

No	Advantages of defense in depth	Disadvantages of defense in depth
1	Reduce the likelihood of a data breach.	Difficult to find the right balance between protective capabilities, cost, performance, and operational concerns.
2	Reduce the chances of the system having a single point of failure.	The three essential principles of security: confidentiality, integrity, and availability, are difficult to apply.
3	Defend against a wider range of threats.	
4	Enhance the efficiency with which valid enquiries and requests are responded to.	For most small businesses, this is a costly kind of security.
5	--	More technical concerns and challenges would emerge from increased complexity.

Figure 6. Advantages and Disadvantages of Perimeter Security

2.5 Zero Trust Architecture

Unlike perimeter security, ZTA incorporates continuous multi-factor authentication, micro-segmentation, encryption, endpoint security, automation, analytics, and comprehensive auditing of data, applications, assets, and services (DAAS).

As companies become more agile, more mobile, with a more cloud-dependent workforce, a perimeter security strategy is no longer an effective means of enterprise security. The ZTA framework effectively minimizes the attack surface, thereby reducing risks. Moreover, it ensures that in the event of a compromise to a device, network, or user/credentials, the resulting damage is promptly contained and remedied.

Zero Trust Architecture (ZTA) is a dynamic cybersecurity concept that shifts the focus of defense from static, network-based perimeters to prioritize users, assets, and

resources. In the Zero Trust approach, assets or user accounts are not automatically trusted based on their physical or network location (such as networks versus the Internet) or asset ownership (whether enterprise-owned or personally owned). This concept is continually evolving in the realm of cybersecurity. It is becoming an answer to modern cybersecurity challenges. ZTA is a security framework that assumes no user or device can be trusted by default (Rose et al., 2020). This means that access to resources is not granted based on where the user or device is located but instead on their identity and behavior. This concept is a major shift from traditional security models, which rely on perimeter defense to protect assets (Figure 5). Perimeter defense aims to prevent attackers from infiltrating the network.

However, if an attacker manages to gain access, they are considered trusted users and are permitted to freely navigate across the network and access unauthorized assets (Benito et al., 2023).

ZTA addresses these challenges by implementing several security controls, such as:

- Micro-segmentation: This feature divides the network into small, isolated segments, making it difficult for attackers to move laterally once they gain network access.
- Least privilege: Dictates that users should only be granted access to perform their job duties.
- Continuous monitoring: Involves constantly monitoring the network for suspicious activity.

Unlike traditional perimeter-based security, ZTA supports a micro-perimeter approach that is based on user access, data location, and an application hosting model.

This micro-segmented network effectively protects sensitive data by requiring verification and authorization for any access.

Perimeter security relies heavily on physical sensors like firewalls, Intrusion Prevention Systems (IPS), and Intrusion Detection Systems (IDS)—to control and secure internet traffic. Once inside the corporate network, trust is implicit and given to everyone.

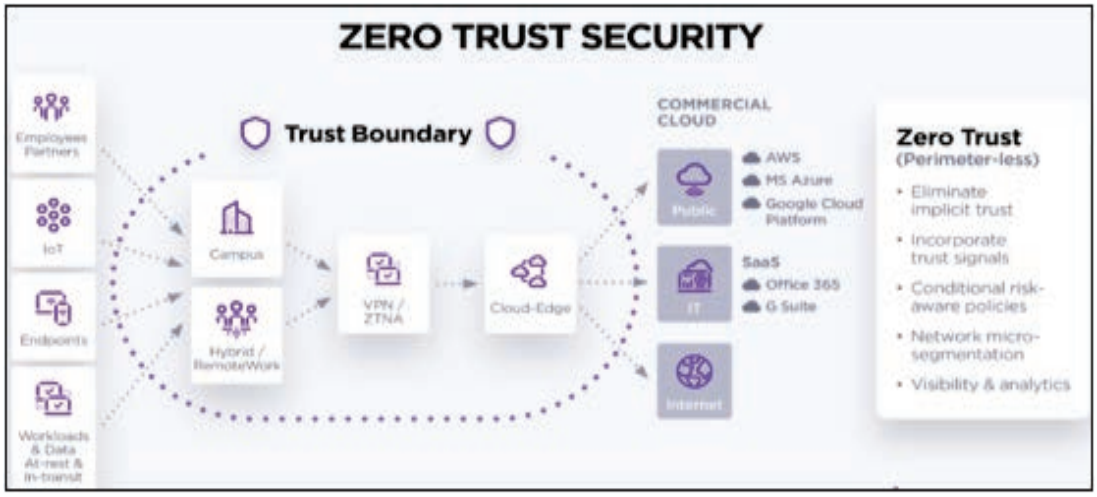


Figure 7. Zero Trust Security

Source: (Rose et al., 2020)

2.6 The Zero Trust Architecture Security Pillars

According to the reference architecture, ZTA encompasses eight security pillars:

User:	The focus is on user identification, authentication, and access control policies that utilize contextual data analysis for validating user connection attempts to the network.
Device security:	Leverage assets' inventory information to determine devices' trustworthiness and compliance to cybersecurity posture.
Network security:	Protection of sensitive information from unauthorized access by users, applications, or devices by using micro-segmentation.
Infrastructure:	Prevention of unauthorized access and potential vulnerabilities to workload and services.
Application:	Protection of user, device, and data components at the application layer.

Data Security:	Classify corporate data and only allow access on a need-to-know basis.
Visibility and analytics:	Monitoring and reporting of security procedures involving access control, segmentation, encryption, and application or data organization.
Orchestration and Automation:	The security and network operational processes of ZTA are enhanced by effectively coordinating actions between similar and disparate security systems and applications (CISA, 2023).

To ensure the effective implementation of a Zero Trust Architecture (ZTA), it is crucial to have a dependable trust evaluation capability, as shown in Figure 7. However, trust schemes and risk evaluation frameworks encounter difficulties in cyber-physical systems (CPS) and critical infrastructures due to the abundance of input sources and the large amounts of contextual data that are collected. To address these challenges, the utilization of Machine Learning (ML) algorithms becomes necessary to automate detection and prevention processes with minimal false positives. This is essential for efficiently enforcing access policies within a ZTA (Syed. et al., 2022).

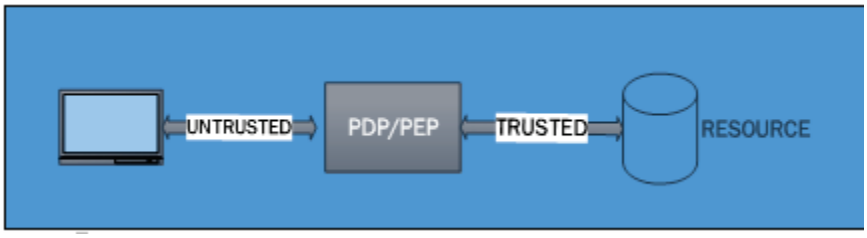


Figure 8. Data Plane

The NIST framework outlines the seven principles of ZTA to effectively implement and achieve its ultimate objective:

- **Resource** –data or computing infrastructure and application
- **Communication Security** – Communication is securely maintained regardless of the location.

- **Session Security** – Access to resources is granted on a per-session basis, ensuring that authentication and authorization for one resource do not extend privileges to others.
- **Access Control** – Access to resources is determined by the policies and is based on the client's identity, application, and requested asset.
- **Minimum-Security Posture** – The enterprise ensures that all corporate devices are secured and monitored.
- **Continuous Authentication** – All resources' authentication and authorization are dynamically enforced. An enterprise that plans to implement ZTA could have an Identity, Credential, and Access Management (ICAM) system alongside multi-factor authentication (MFA) for enhanced security.
- **Information Logging** – The enterprise gathers extensive information regarding the existing state of network infrastructure and communications, utilizing this data to enhance its security posture. (Levine & Tucker, 2023).

Features	Perimeter Security	Zero Trust Architecture (ZTA)
Approach	Trust but verify	Trust nothing and verify everything
Trust Boundary	External (Non-trust), Internal (Trust)	Micro Segmentation
Access Control	IP (Port, Protocol) based access control	Data-centric access control
Communication Encryption	External (Encryption)/Internal (No Encryption)	Full traffic encryption
Authentication	Once verification at initial access	Before access and continuous verification
Security Policy	Pre-defined rules and common policies	Fine-grained rules and adaptive policies (Needs Security Assessment)
Security Managements	Individual Monitoring and visibility	Visibility, automation orchestration of behavior, devices, services, and security

Figure 9. Perimeter Security vs. ZTA

Source: (Sarkar et al.,2022)

2.7 ZTA Logical Components

The Zero Trust Architecture (ZTA) consists of multiple components that collaborate to safeguard data and network resources. Figure 3 illustrates these components. Their primary objective is to ensure the authenticity of the network user and validate the legitimacy of their request.

The Policy Decision Point/Policy Enforcement Point (PDP/PEP) determines the level of confidence in the user's identity regarding each request. Once authentication is complete, PDP/PEP assesses whether the user possesses authorization to access specific information assets based on their verified identity. It verifies if the device used for the request meets appropriate security standards. Various factors like time, location, and security posture may also be considered to evaluate any potential changes in confidence level.

Each component within ZTA has a distinct role in adhering to this model:

- **Policy Engine (PE):** This component provides access to users of resources by using company policies to deny or allow access to the target resources. It works in tandem with the policy administration, CDM systems, and threat intelligence components to determine access appropriateness before making the decision to either grant or deny access.
- **Policy Administrator (PA):** This component is used to either create or block the communication channel between the user and resources. To access the network resources, PA creates a token and validates the user's credentials before terminating or allowing access.
- **Policy Enforcement Point (PEP):** This component enables, monitors, and terminates the user's and resources' connection. The PEP communicates with PA to send requests and receive updates related to policy from PA.
- **Continuous Diagnostics and Mitigation (CDM) System:** This component collects company assets information. It passes that information to the PE component on whether the asset making a request has the latest Operating System (OS) and/or any vulnerabilities. Additionally, it ensures that policies are enforced for non-enterprise devices that are connected to the enterprise network.
- **Industry Compliance System:** This component checks to ensure that the organization complies with rules and regulations within the industry in which it operates.

- **Threat Intelligence feed(s):** Provides attack or vulnerability information from external and internal sources to PE, which helps decide whether to grant or deny asset access requests.
- **Network and System Activity Logs:** Provides real-time feedback from activity logs, network traffic, and other security events.
- **Data Access Policies:** Stores the company's resource access rules and policies.
- **Enterprise Public Key Infrastructure (PKI):** Logs and generates certificates issued by the organization to its resources, services, and applications.
- **ID Management System:** Creates, stores, and manages user accounts and records in the organization. It contains information such as names, ages, email addresses, and other basic information like roles and access attributes.
- **Security Information and Event Management System (SIEM):** Collects security-related information from activity logs that are analyzed for policy creation.

The Trust Algorithm (TA) is a process utilized by PE to determine whether to permit or refuse access to a resource (Figure 10). PE gathers information from various sources, including the policy database, subject attributes and roles, historical behavioral patterns of subjects, and threat intelligence sources.

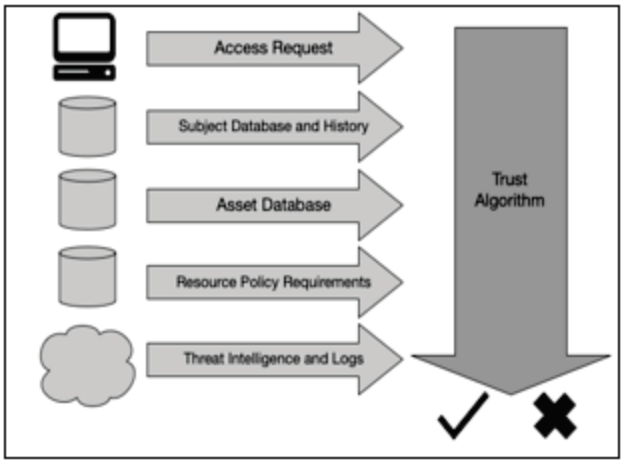


Figure 10. Trust Algorithm Input

ZTA determines the trust for access requests based on the computational results that help establish the confidence level of the requesting resource before allowing or denying an access request. The algorithm that drives access decisions checks various factors and treats the network as compromised:

- **Access request:** checks for OS version, if the software used to request access is an approved application and abides by patch level. Access to assets might be restricted or denied depending on these factors and the asset security posture.
- **User Identification:** checks for user and other attributes such as time and location to authenticate by the PE and used by the TA to compute the confidence level of the requesting resource.
- **Asset Database and Observable Status:** this database contains the status of all resources and is utilized to compare against the observable behavior of the requester, such as operating system, patch level, and location, before making an access decision.

- **Resource Access Requirement:** checks for compliance with basic security policy requirements.
- **Threat Intelligence:** houses information such as attack signatures from various sources to identify potential attacks. (Syed et al., 2022)

Each of these factors is assigned different weights based on their importance, and once the decision is made by the TA, the PE which makes policy decisions based on various factors, passes the results to the PA and then to the PEP, which determines whether to enable or disable the communication.

2.8 Summary and Conclusion

This chapter provided a comprehensive literature review of the existing research on perimeter security and Zero Trust architecture models, tools, and controls for addressing the risks relating to data breaches and ransomware. Research on preventing data breaches and ransomware is still emerging, especially with businesses' shift to cloud computing and remote connectivity that increase the attack surface compared to when systems were hosted on-premises and employees were working at the corporate offices. Considering these prevailing changes, organizations must shift from a perimeter-based security architecture to a Zero Trust architecture in order to effectively prevent data breaches and the increasingly prevalent threat of ransomware. Previously, organizations could rely on the perimeter-based security approach as a means of safeguarding their data. However, this approach is not as effective in the current threat landscape. Perimeter-based security assumes that all devices and users inside the perimeter are trusted, which is no longer the case. On the other hand, ZTA is a more secure alternative since it assumes that no device

or user can be trusted, and it requires authentication and authorizations for all access to sensitive data.

Chapter 3. Methodology

3.1 Overview

This chapter offers a comprehensive overview of the research methods utilized in this praxis. Section 3.2 discusses the reference architecture for zero trust implementation. Section 3.3 discusses the tenets of Zero Trust Architecture. Section 3.4 discusses ZTA's principal architecture as proposed by the DoD. Section 3.5 discusses the micro-segmentation implementation approach. Section 3.6 discusses the implementation of the three-tier systems that were used for this praxis. Section 3.7 discusses the praxis machine learning models. Section 3.9 presents the evaluation process of the proposed hypotheses. Section 3.10 discusses the data preparation approach. Section 3.11 discusses the data processing. Section 3.12 discusses the handling of imbalanced data for the praxis. Section 3.13 discusses the sampling approach. Section 3.14 discusses the model validation processes. Section 3.14 discusses XGBoost algorithm. Section 3.15 time series data analysis method. Section 3.16 discusses how to handle imbalanced data. Section 3.17 discusses near miss under-sampling. Section 3.18 discusses the two-sample Z-test. Section 3.19 discussed the Model Validation Process. Finally, the SHAP features model analysis is discussed in Section 3.20.

3.2 Reference Architecture

There are three primary approaches to implementing ZTA, which differ depending on the components deployed and the data sources that drive an organization's PE.

- **Identity Governance**: This approach primarily relies on user and device identities for PE to make policy decisions. Risks are assessed based on user identities, contextual information, and available resources.

- **Micro-Segmentation**: This approach utilizes PEP to protect the resource or data against unauthorized access. It employs micro-segmentation to effectively detect and prevent lateral movement by potential attackers.
- **Network Infrastructure and Software-Defined Perimeters:** This approach utilizes the SDP for enforcing access control and ensuring secure communication with back-end applications.

Throughout this chapter, we will frequently refer to the Department of Defense's (DoD) ZTA reference architecture as a reliable source for implementing ZTA. This architecture serves as an informative guide that influences and limits the development of various architectures and solutions. The widespread nature of remote work and the increasing utilization of cloud computing have compelled numerous enterprises to tackle the security obstacles associated with embracing digital transformation.

The implementation of ZTA was carried out to gather data that will be used to validate the hypotheses for this praxis.

ZT architecture introduces novel security concepts, including data centricity and conditional access, to achieve the fundamental principle of not blindly trusting data requests, applications, or resources. This effectively addresses certain weaknesses in perimeter security. ZTA also ensures a gradual approach to implementing security policies within these capabilities (Rose et al., 2020).

To address the deficiencies of the legacy security model, ZTA adopts the following approach:

- It assumes that all subjects are malicious until their identity is validated by the policy engine, which then determines whether they are authorized to access the resource.
- It decreases the likelihood and extent of unauthorized data access and potential exfiltration by implementing comprehensive access controls at the data level.
- By improving visibility into users, devices, and network traffic, it reduces the time taken to detect breaches while enhancing anomaly detection.
- It reduces the risk area by implementing micro-segmentation, which helps protect assets and manage access by considering user identity, roles, and context.
- It simplifies compliance reporting by providing a clearer view of authentication and access events.
- It provides continuous and robust authentication of a subject, depending on the level of risk associated with accessing specific data.

A security architecture focusing on data starts by identifying PII and critical applications for implementing Zero Trust (ZT). This process involves discovering the users and flows to develop a security policy. The control plane comprises the ZT policy controller, with automation and orchestration capabilities serving as a gateway for new conditional access policies. The integration between these technologies is achieved through APIs. The advancement of artificial intelligence (AI) and robotic process automation (RPA) enhances and updates the policies implemented from the control plane (Rose et al., 2020).

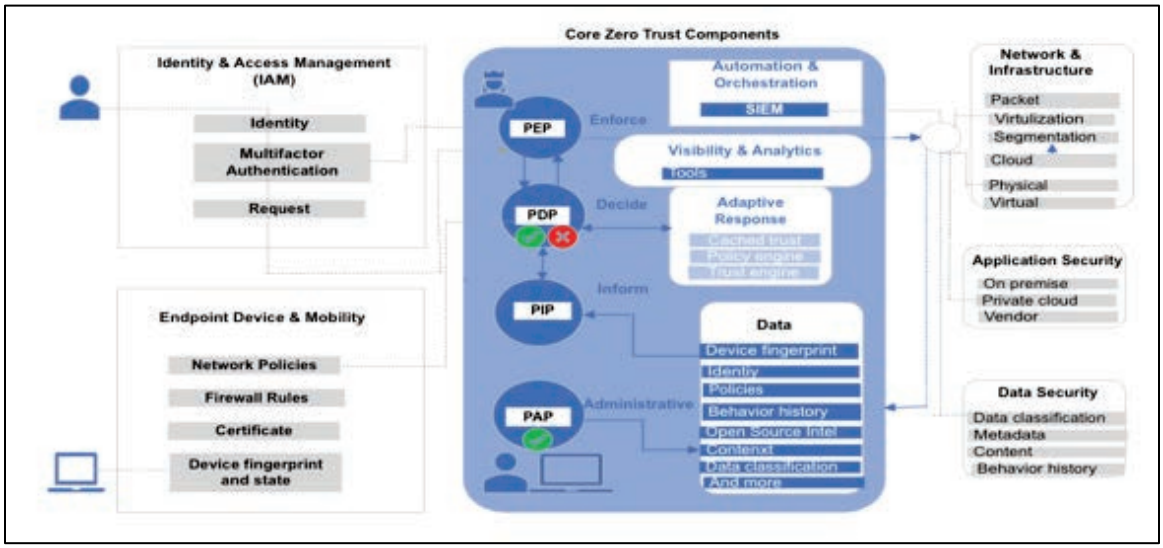


Figure 11. Core ZTA Components

3.3 Tenets of Zero Trust

The ZT security model revolutionizes the approach to implementing access to resources. It is determined by a dynamic policy considering various factors, such as the observable state of user and endpoint identity, application/service, requesting asset, and even behavioral and environmental attributes. Confidence levels are established based on multiple attributes of the subject undergoing authentication.

ZT is governed by five essential principles which serve as the fundamental building blocks and have a profound impact on all aspects of ZT:

- **Assume a Hostile Environment:** There are malicious personas in both internal and external environments. All users, devices, applications, environments, and all other network perimeter entities should be treated as untrusted.
- **Presume Breach:** The financial industry faces hundreds of thousands of cyber-attacks daily. Companies should operate and defend resources with the awareness

that adversaries may exist within the environment. As such, thorough scrutiny of access and authorization decisions to enhance response outcomes should be continuously performed.

- **Never Trust, Always Verify:** Deny access by default. Utilize authentication and explicit authorization for every device, user, application, and data flow. Implement least privilege principles along with multiple attributes and dynamic cybersecurity policies.
- **Scrutinize Explicitly:** Securely access all resources consistently by leveraging multiple attributes (both dynamic and static) to establish confidence levels on the resource**'s** contextual information. Resource access is conditional, with continuous validation based on location and confidence levels resulting from actions taken.
- **Apply Unified Analytics:** Employ unified analytics for Data, Applications, Assets, and Services (DAAS) to include behavioristics analysis while logging each transaction (Rose et al., 2020).

3.4 Reference Architecture (RA) Principles

The ZTA framework is an approach to security that utilizes a series of guiding principles in creating the RA:

- **Principle #1:** Networks should not assume any trusted zone, whether implicit or explicit.
- **Principle #2:** Strict enforcement of identity-based authentication and authorization for resources accessing the infrastructure, data, and services.

- **Principle #3:** Strict enforcement of machine-to-machine (M2M) authentication and authorization for communication between servers and applications.
- **Principle #4:** User and device behaviors are monitored in near-real-time to generate risk profiles that authorize access to resources.
- **Principle #5:** Sensitive data is encrypted both in motion and at rest.
- **Principle #6:** Continuous monitoring, collection, storage, and analysis of all events to assess compliance with security policies.
- **Principle #7:** Centralized policy management and distribution.



Figure 12. ZT Access Flow

Some of these principles can also be linked to traditional security practices, but the integration of new principles like Principles #1, 2, & 7 significantly bolster data security when Zero Trust Architecture (ZTA) is applied within the network and addresses certain weaknesses found in legacy security.

In the model illustrated in Figure 12, a subject requires access to an enterprise resource. Access is granted through a policy decision point (PDP) and its corresponding policy enforcement point (PEP). The Trusted zone represents an area where all entities are trusted to at least the level of the PDP/PEP gateway. The PDP/PEP applies a set of controls to ensure that all traffic beyond the PEP has a consistent level of trust. However,

the PDP/PEP does not apply any additional policies beyond its position in the traffic flow (Rose et al., 2020).

In the ZTA security model, users, subjects, and devices must undergo proper authentication and establish a certain level of trust to be granted access to enterprise resources. User access is determined by the sensitivity of the data or functionality being accessed as well as the permissions associated with requested roles. Furthermore, subject and device attributes must align with predefined risk tolerances to be authorized. (Kennedy. et al., 2022).

Effective user authentication involves utilizing multiple authentication factors including one-time passwords, biometrics, tokens, location information, or knowledge-based answers. In terms of device authentication, options encompass diagnostics and software versions that can be combined with enterprise-issued certificates. To establish trust in legitimate and authorized access attempts, various elements such as device security posture, time of day, and geolocation are considered (Kennedy et al., 2022).

In ZTA's application-to-application communications approach, IP authentication alone is insufficient as in traditional security models. Access requires strong authentication credentials and adherence to predefined communication and application dependency maps while conducting source system security posture checks (Kennedy et al., 2022).

All these factors are carefully considered to determine whether communication or access requests should be permitted as expected or if they indicate potential lateral movement by malicious actors that must be blocked or flagged for further investigation. (Kennedy et al., 2022).

Architecture Pattern	Artifact Type	Architecture Pattern uses or supplies these capabilities
Domain Policy Enforcement for Resource Access	SV-1 SoS	Continuous Authentication, Conditional Authorization, Macro/Micro Segmentation
Software Defined Perimeter	OV-2	Conditional Authorization, Micro segmentation, Encryption
ZT Broker Integration	SV-1 SoS	Continuous Authentication, Conditional Authorization, Device Hygiene
Micro-segmentation via NGFW and SDDC	SV-1 SoS (multiple)	ZT Enabling Infrastructure, Software Defined Networking
Macro-segmentation via SD-WAN	SV-1 SoS	ZT Enabling Infrastructure, ZT Orchestration, SDN, SDDC

Figure 13. ZT Design Pattern

Figure 13 provides multiple options for implementing ZTA according to the Department of Defense ZT Reference Architecture (Department of Energy, 2006).

3.5 Micro-segmentation

The ZT micro-segmentation approach is designed to create logical access boundaries around an application or group of applications based on identity and context. This approach enhances security at a detailed level, safeguarding enterprise resources. By implementing micro-segmentation, only specific devices, workloads, or applications are granted access. This isolation of access ensures increased protection against lateral cyber-attacks. In the event of a cyber breach, micro-segmentation only contains the attack to the affected area, significantly reducing risk exposure compared to traditional approaches providing access to the entire network.

To effectively control data breaches and ransomware attacks, the ZT architecture incorporates protocols that hide applications from public view. The trust broker manages identity, context, and access requests by validating them against associated policy rules

for each resource type. With ZT's authorization process, granting only necessary privileges for each request type minimizes the threat surface.

The micro-segmentation approach centralizes policy management for resource access, which provides the ability to adapt quickly to new threats in the network, unlike the perimeter security architecture where access policies are managed at the domain level.

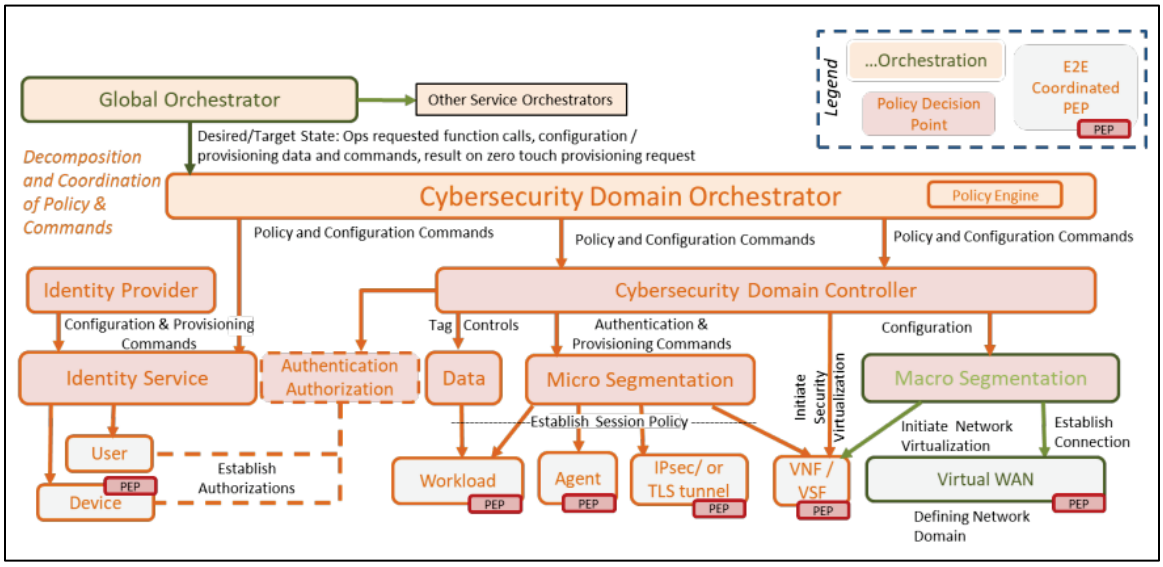


Figure 14. ZTA Centralized Orchestration & Policy Management

Source: (Department of Energy, 2006)

Coordinating policies among the different components of ZTA establishes a defense-in-depth approach that ensures the preservation of data integrity, availability, and confidentiality.

According to the NIST.SP.800-207 framework, there are multiple ways in which an enterprise can implement ZTA. These implementation approaches differ based on the components utilized as the primary source of policy rules for an organization. Those

approaches are the usage of enhanced identity governance, the usage of micro-segmentation, and the usage of network infrastructure software-defined perimeters.

To test the hypotheses discussed in this praxis, the ZTA using micro-segmentation was used. There are three different methods for implementing micro-segmentation, and each one is different depending on the layer of the network.

Network-based micro-segmentation:

This method is employed to implement micro-segmentation at the network layer by utilizing VLANs for segment creation, while IP constructs or ACLs are used to configure and enforce policies. Additionally, smaller networks can benefit from the use of segmentation firewalls.

Hypervisor-based micro-segmentation:

This method employs a hypervisor to isolate and segment workloads, making policy enforcement more agile. It also enables policy enforcement beyond the workload by utilizing the hypervisor itself.

Host-based micro-segmentation:

This approach utilizes the software-defined framework to implement micro-segmentation. It effectively utilizes the built-in native firewall functionality of workloads to offer distributed fine-grained policy controls. By engaging the services of an agent, host-based micro-segmentation can be effectively implemented in diverse environments including data centers, clouds, bare metal, and hybrids.

This praxis used host-based micro-segmentation. The agent was installed in the MySQL database, on the web server, and file server in the AWS environment. ColorTokens, A ZTA company provided the agent that was used for this praxis.

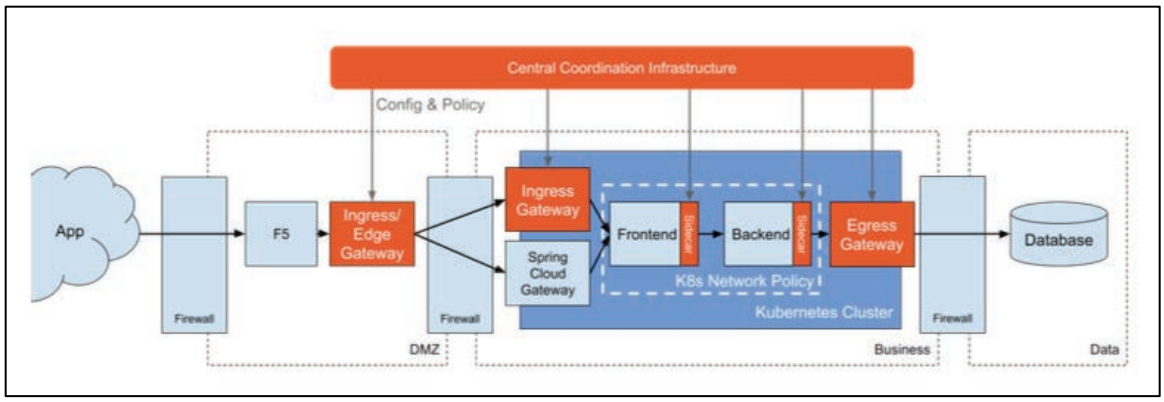


Figure 15. Policy Deployment for a Three-tier Application

Figure 15 shows the NIST reference architecture for a three-tier application policy enforcement.

Sidecar – This feature intercepts and manages all incoming and outgoing traffic, as well as facilitates internal communication between services within the infrastructure.

Ingress gateway – It controls the exposure of applications within the cluster to the internet (e.g., managing what names, certificates, ports, protocols, and application endpoints are served to the outside of the cluster)

Egress gateway – The purpose of this feature is to manage how applications within the cluster interact with external entities. This feature is employed for filtering, logging, and enforcing identity-based policies that determine which outbound calls are permitted and facilitate credential exchange processes.

Edge gateway – The feature accepts incoming traffic from external sources prior to reaching the ingress gateway. Additionally, it efficiently balances the load across various clusters or sites,

providing precise control. This feature allows the termination of external traffic and facilitates failover at an infrastructure level.

3.6 Setting up the 3-tier Application Infrastructure for the Praxis:

To conduct the study to address the praxis' research questions and corresponding hypotheses, the deployment of three Linux VMs in the EC2 was performed. This guide walks through the steps taken to implement the system using Ubuntu 20.03 LTS.

On all VMs make sure you have the latest and greatest:

sudo apt update

sudo apt upgrade

Set the hostname for the VMs as follows and register them in your local DNS if possible:

- Wordpress-web0
- Wordpress-app
- Wordpress-db

Please refer to Appendix A for the step-by-step implementation process followed to deploy the ZTA and Perimeter security systems used for this praxis:

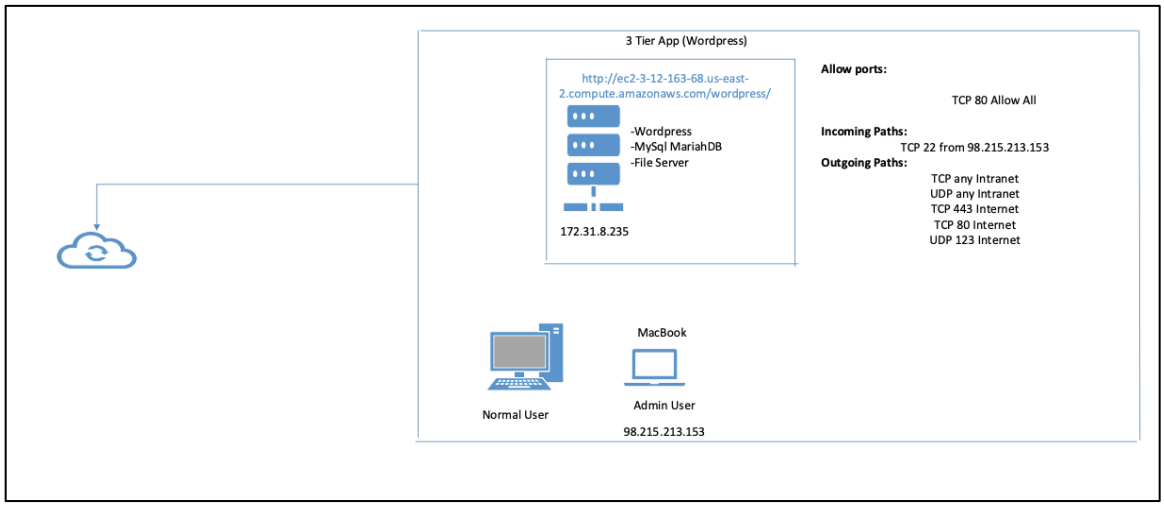


Figure 16. Praxis Application Architecture



Figure 17. ZTA Based Application

Repeat the same steps to create a non-ZTA environment that will also be used for this analysis:

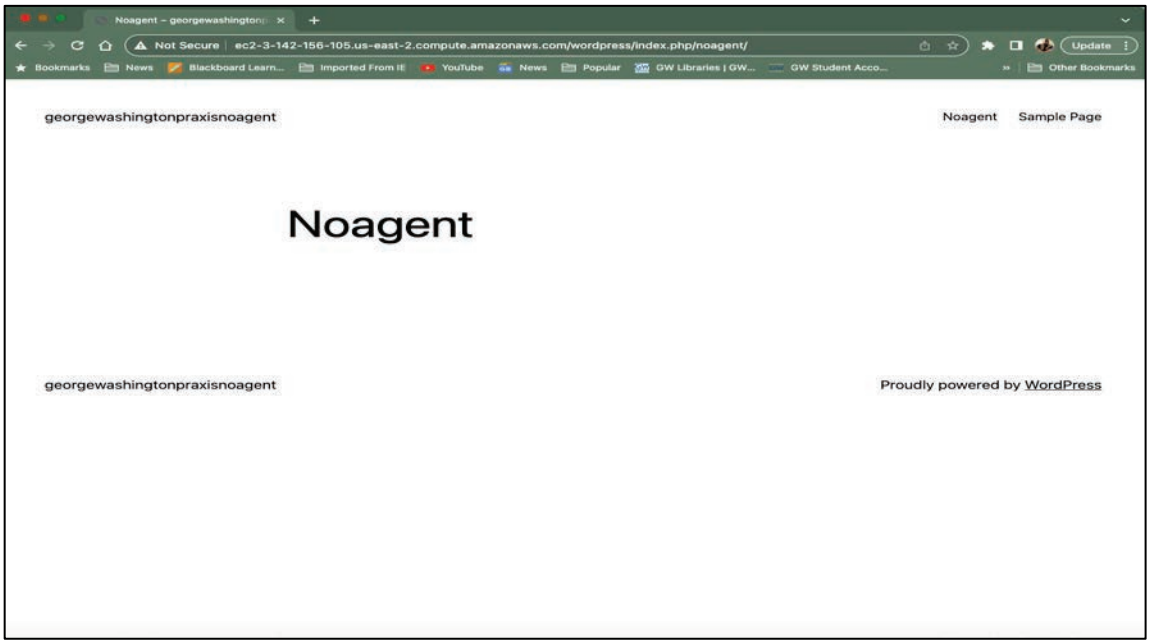


Figure 18. Perimeter Security Based Application

3.7 Proposed Machine Learning Model

The ZTA model, mentioned in SP800-207, operates on a foundation of guiding principles. These principles include the assumption of a breach, implementation of least privilege, and establishment of a robust degree of trust. Trust is built based on various factors such as roles, attributes, authentication context, and sensitivity of the target data (Rose et al., 2020).

The following ZTA implementation proposal (Figure 19) aims to monitor the data flow into the network and access requests to network resources. This architecture guarantees that resource access is controlled and verified through implicit permission. The current ZTA concept is a dynamic cybersecurity approach that shifts defenses from static, network-based boundaries to prioritize users, assets, and resources. The operation

assumes that assets or user accounts should not be given implicit trust solely based on their physical or network location (e.g., networks versus the Internet) or ownership (whether owned by an enterprise or personally owned). (Nemirovsky, 2023).

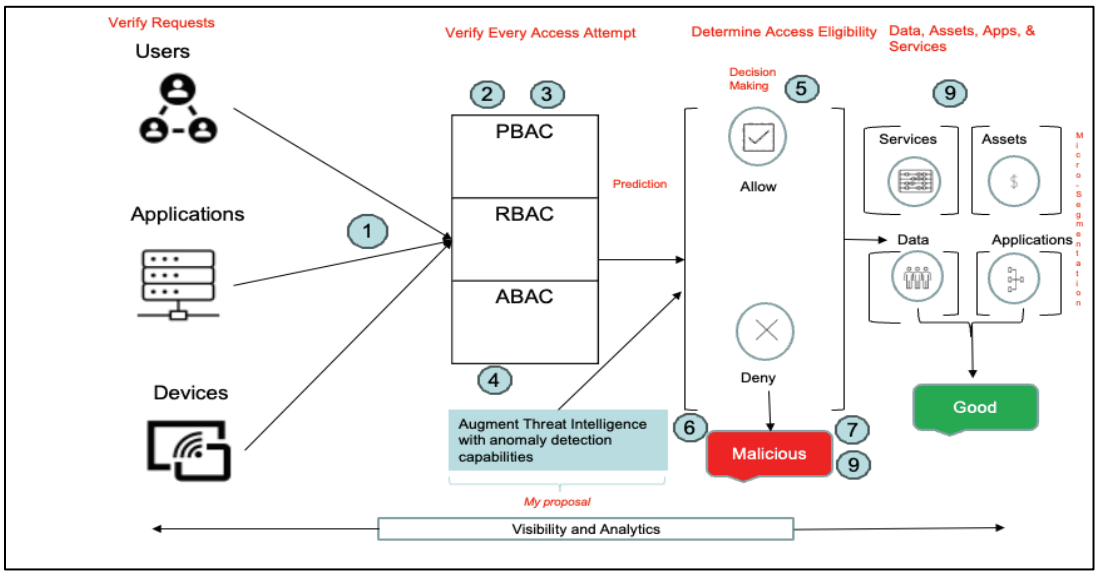


Figure 19. Proposed Model

Identity and Access Management (IAM) plays a critical role in ensuring that authorized and legitimate individuals or users can access enterprise resources. In Figure 19, users, applications, or devices are required to authenticate themselves using various authentication methods depending on the type of request. These methods include Policy-Based Access Control (PBAC), which combines the user's role with policies to determine their access privileges; Role-Based Access Control (RBAC), which authenticates and restricts access based on a user's predefined role; and Attribute-Based Access Control (ABAC), which authenticates subjects based on a combination of attributes that match their resource requirements for performing their tasks (Puthiyavan, 2023).

As shown in Figure 19, the model developed for this study consists of three sections used to evaluate the hypotheses guiding this research. The first section addresses Hypothesis 1, which primarily focuses on authenticating users, devices, and services prior to granting access. The second section concentrates on calculating trust to ascertain the appropriateness of resource authorization, as well as the level of authorization that should be bestowed. The third section focuses on the micro-segmentation of enterprise assets, aiming to prevent data breaches and restrict lateral movements.

The model uses contextual data to automate the detection of unauthorized access and calculate trust factors and entitlement of the access request. Its goal is to address the limitations of manual policy management methods by incorporating automation technologies and offering a structured approach to policy management.

The proposed model combines the analysis of user access information and contextual data in order to enable policy evolution and ensure alignment with organizational data access policies and technological changes (Hummer et al., 2016). The Sequence of Access Request in this ZT model is as follow:

1. A user, device, or application initiates an access request.
2. The system verifies the authenticity of the subject and validates the request.
3. The PDP/PEP makes a judgment to allow access to the resource based on authentication and authorization, following the zero-trust principle.
4. The system assesses the degree of certainty regarding the individual's identity for every request.
5. Based on the confidence level in the subject's identity, the system determines if the access request to the resource is permissible.

6. The system checks if the device used for the request has appropriate security measures in place.
7. Other factors such as time, location, and security posture of the subject are considered by the system and can impact the confidence level (e.g., time, subject's location, subject's security posture).
8. The access request is denied or terminated if the confidence level does not meet the threshold.
9. Access to the resource is granted if the confidence level meets the specified threshold (Syed et al., 2022).

3.8 Proposed Threat Intelligence Enhancement

The ZT cybersecurity architecture brings in new and innovative security concepts, such as data centricity and conditional access, to achieve the core principle of never fully trusting requests for data, applications, or resources. Adding to the idea of explicit verification, assuming a breach in the environment enhances the accuracy of the security policies implemented within these capabilities (Department of Energy, 2006).

These innovative concepts make ZTA a viable cybersecurity solution for the modern business environment. However, its threat intelligence component relies only on a signature intrusion detection feature (Wylde, 2021). This makes it potentially vulnerable to unknown attacks. To address this weakness, this praxis proposes enhancing ZTA's threat intelligence capabilities by incorporating an anomaly detection component using supervised and unsupervised methods.

The machine learning solution will complement ZTA's existing threat intelligence capabilities by introducing anomaly detection features for users, devices, and applications

that connect to the network environment. This will enable the determination of threat levels before granting access to enterprise resources. The anomaly detection component will identify unknown attacks and block access to network resources.

The algorithm developed in this research will dynamically analyze traffic by calculating intrusion detection and assigning an accuracy score. This score will determine whether a connection poses a potential threat, thereby allowing or denying access to enterprise resources based on data classification. The hypothesis statement was designed to research and prove if such a feature will add to the resilience of the ZTA from unknown or zero-day attacks.

3.9 Evaluation of the Proposed Hypotheses

The study used two types of data: Bank Churners data obtained from the internet that has PII (Personally Identifiable Information) data, which was added to the database to validate hypotheses 1 and 2. This dataset contains information such as Client Number, Age, Gender, Education Level, Income, Credit Limit, Revolving Balance, etc. The data was stored in databases located within both ZTA (Zero Trust Architecture) and Perimeter-based security environments (Figure 17 & Figure 18). The goal of this experiment is to simulate attacks on both environments and detect any vulnerabilities that could be exploited to gain access to the PII data. A comparison was then conducted between the two security architecture approaches to determine if there are any differences in their effectiveness in protecting the underlying systems and databases. The assumption made is the ZTA environment should not expose ports, protocols, and applications outside the cluster.

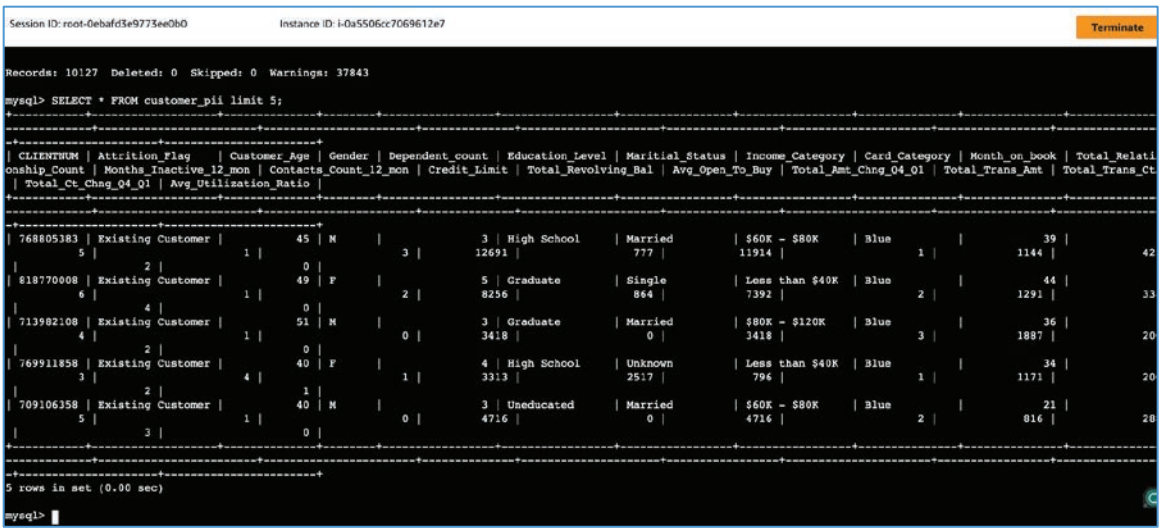


Figure 20. Praxis Database

The second dataset used for testing the hypotheses was collected from simulated network attacks against the ZTA and non-ZTA environments designed to evaluate the effectiveness of security controls implemented in both security architecture approaches. Manual attacks were conducted to exploit identified vulnerabilities, assuming that the ZTA environment would effectively hinder any real system penetration by preventing lateral movements.

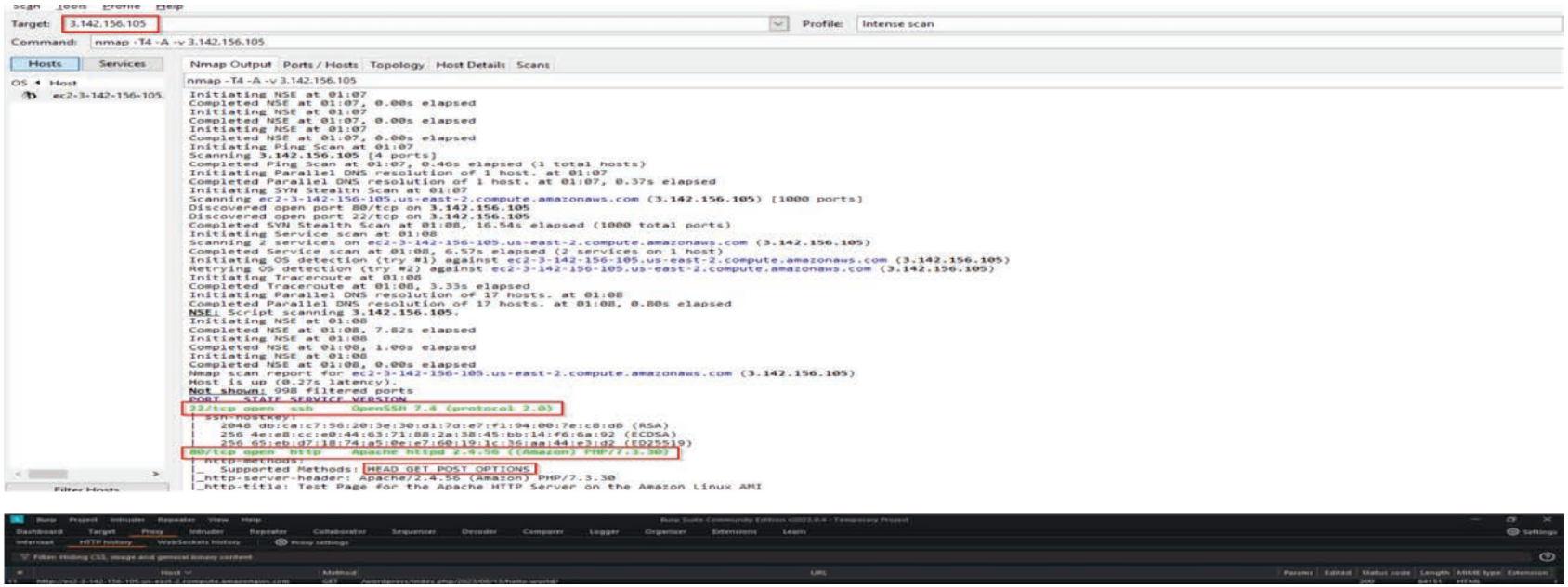


Figure 21. Nmap Scanning of Perimeter Based System

Various tools were used to simulate automated attacks, such as scans run by using Qualys, Nmap, Zap, Burpsuit, SQLMap, Dirsearch, Nuclei, and Wpscan.

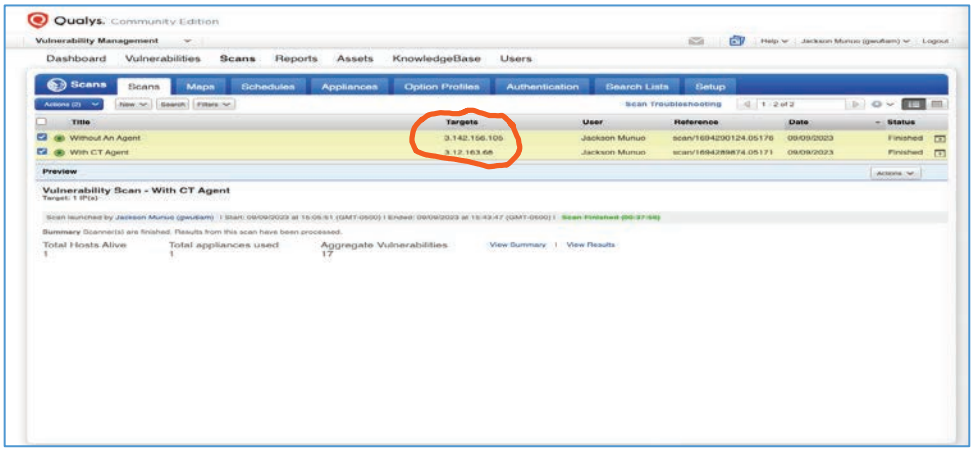


Figure 22. Scanner Dashboard

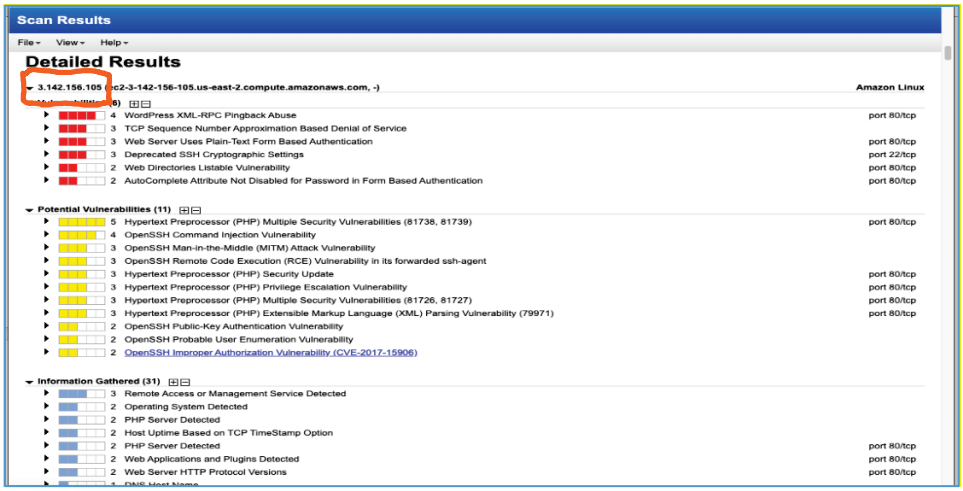


Figure 23. Perimeter Based Security Vulnerability Scan Results

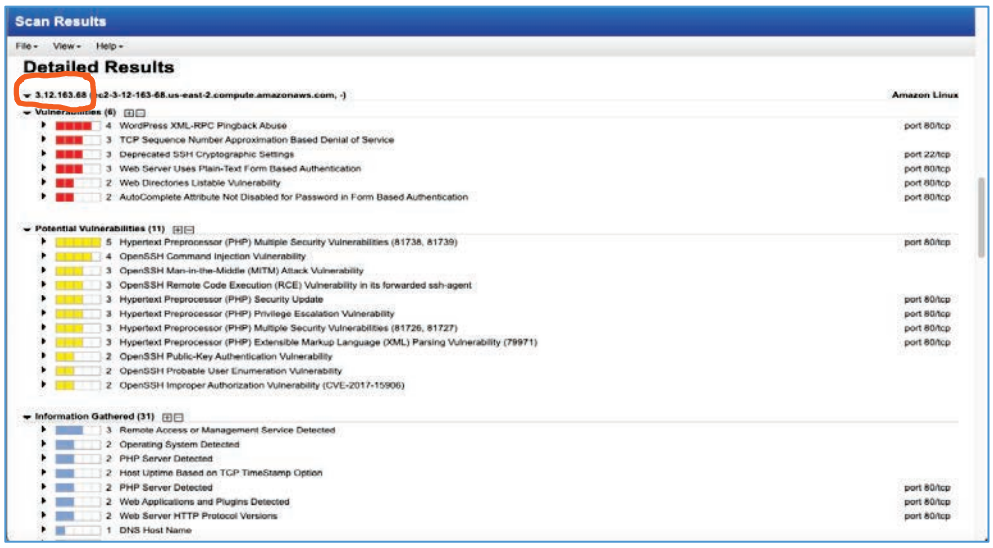


Figure 24. ZTA-Based Environment Vulnerability Scan Results

Collection of traffic data from simulated attacks in the ZTA environment was performed to help test hypotheses for this study. This data was used to create machine learning models for anomaly detection, both for testing and training purposes. In this study, several algorithms were examined, and the models were refined and assessed by utilizing test data to evaluate their performance metrics. The objective of this section is to ascertain the feasibility of developing an anomaly detection model that can effectively identify anomaly attacks within the ZTA environment.

There are two basic types of Machine Learning Models: Unsupervised and Supervised.

The key distinctions between Supervised and Unsupervised Learning lie in the types of data they handle and the algorithms they employ. Unsupervised Learning utilizes unlabeled data along with self-guided algorithms, whereas Supervised Learning relies on labeled data alongside predefined training algorithms.

Furthermore, their primary objectives differ as well. The main objective of Supervised Learning is to perform predictive analytics, while Unsupervised Learning primarily aims to identify patterns within the data.

3.10 Data Preparation

The data utilized in this study was created from two environments built specifically for this praxis, as described in Section 3.7. One environment consists of a web application running on a Zero Trust (micro-segmentation) architecture with an agent installed on virtual hosts (web server, database, and storage). Another environment, based on perimeter security architecture, is also deployed for this praxis with traditional security controls, including firewalls, IDS, and IPS. The data was generated from simulated attacks conducted simultaneously on both environments.

The first scans were designed to test the access policies of both environments. This was an application black box penetration test designed to test vulnerabilities of the public-facing web applications to potential cyber breaches. The objective of this exercise was twofold:

1) Assess if a remote network intrusion is possible from an outside attacker without prior knowledge of the targeted servers.
2) All activities were carried out to simulate the behavior of a malicious actor involved in a targeted attack against both environments, aiming to:
    - Identify if a remote attacker could penetrate web application security.
    - Compare the effectiveness of each environment in thwarting data breaches and ransomware attacks.

Table 1. Data Dictionary of Research Data Source

Research Data Source	Description	
Web Scan Logs – Perimeter Security	A cumulative report of simulated web penetration attacks to test vulnerabilities and security controls effectiveness in this security architecture.	The exercise ran from Sept 4 until Sept 28, 2023. Identified 48 vulnerabilities.
Web Scan Logs – ZTA Security	A cumulative report of simulated web penetration attacks to test vulnerabilities and security controls effectiveness in this security architecture.	The exercise ran from Sept 4 until Sept 28, 2023. Identified 0 vulnerabilities.
Manual Attacks	A cumulative report of brute force attempts to steal usernames and passwords.	1 report
BankChunners table	Credit Card Customer Prediction	10,000 customers listing age, salary, marital status, credit card limit, credit card category, etc.

3.11 Data Preprocessing

The data used in this praxis was collected from simulated attacks and was in the text format. The data was not well organized in a readable or column format. Each of the scans had more than 300,000 rows of data that needed to be parsed to prepare it for the analysis phase. For this praxis, we only analyzed 10,000 records. The traffic data had the following labels: ip_addresses, timestamps, http_requests, http_statuses, response sizes, and user_agents. A description of each category is provided in Table 2 below.

The data represent several simulated attacks directed at both ZTA and perimeter security deployments. The data from the log file contains the detailed simulated attack.

To prepare the data, this praxis followed the following steps:

- Load the ‘logs.csv' file created by scans into Google Colab Pro.
- Preprocess the data, which involved dealing with missing values, encoding categorical variables, and scaling numerical features.

Detecting attack patterns from log data typically involves using machine learning algorithms for anomaly detection or classification, depending on the nature of the dataset.

Table 2. Simulated Attacks Categories

Data	Description
IP Addresses	Internet identifier or address that is the source of the attacks.
Timestamps	It gives an indication as to when a certain attack occurred. Timestamp includes the date and time an event occurred.
HTTP Requests	An attacker makes web requests to a server to retrieve a web page or other resources or data using HTTP methods such as POST, GET, PUT, DELETE, etc.
HTTP Statuses	Status codes indicate a successful or failure to complete a specific HTTP method request.
Response Sizes	The size of the HTTP response or packet.
User Agents	Request header that informs server and network identify the application, operating systems, and version of the requesting agent or attacker.

Table 3. Event Codes

HTTP Event ID	Description
200	Success status response code that implied that the request has succeeded.
400	The status code indicates that the server cannot process the bad request.
403	The status code indicates that the server has received the request but refuses to authorize it.
404	Status code that indicates the website has blocked the requesting IP.
405	Status code that indicates that the requested page exists.
501	The status code signifies that the server does not recognize the requested method.

Table 4. HTTP Methods

Method Name	Description
GET	Transfer a current representation of the target resource.
TRACE	Perform a loop-back test by sending a message along the path to the target resource and receiving it back.
POST	Conduct processing on the content requested, specific to the resources.
CONNECT	Create a tunnel to the server through the desired resource.
DEBUG	Detects and corrects flaws in an application.

Upon review of the event logs, the attacks were divided based on the HTTP statuses.

Here is a general outline of how this praxis approached the task using Python and its machine-learning libraries like pandas, matploit, etc.:

3.11.1 Feature Creation

The predictive models in this praxis were developed using preprocessed and transformed data, which resulted in the creation of various features.

- Extract relevant features from the log data. This might include features related to IP addresses, HTTP requests, and timestamps.
- Create a target variable that indicates whether each log entry is a normal or an attack pattern (labeling).

3.11.2 Split Data

- Split the dataset into a training set and a testing/validation set. The data was split into 80% training and 20% testing from the log that had more than 300,000 unique records. The training data was then used to train the model and evaluate the performance using the testing dataset. The goal was to avoid overfitting and obtain accurate results on how the model will function.

3.11.3 Model Selection

- For this praxis and based on the dataset, a selection of the appropriate machine learning model for the task was important. I used logistics regression as a baseline then tree-based models such as Logistics Regression, Random Forest, and XGBoost.

3.11.4 Model Training

- 80% of the dataset was selected to train the model.

3.11.5 Model Evaluation

- 20% of the traffic dataset was used to evaluate the model's performance on the testing/validation set using relevant metrics (e.g., accuracy, precision, recall, F1-score, ROC AUC, etc.).

```
Accuracy: 1.00
Classification Report:
              precision    recall  f1-score   support

           0       1.00      1.00      1.00      1151
           1       0.99      1.00      1.00       692
           2       0.50      0.17      0.25         6

    accuracy                           1.00      1849
   macro avg       0.83      0.72      0.75      1849
weighted avg       1.00      1.00      1.00      1849
```

Figure 25. Model Evaluation

3.11.6 Tuning and Optimization

- If needed, fine-tune hyperparameters or try different models to improve performance.

3.12 Logistic Regression

A statistical approach and Machine Learning algorithm known as classification based on probability is used to solve problems involving categorical dependent variables.

Logistic regression is extensively employed in binary classification problems, where the outcomes can be categorized as true or false, yes or no, and so on. For instance, it can be utilized to determine if an email is classified as spam (1) or not (0). This algorithm utilizes the sigmoid function to calculate the probability of a particular label (Awan, 2023).

Logistic regression falls under the category of Supervised Learning, which is characterized by algorithms that learn from labeled datasets and analyze the training data. These labeled datasets consist of inputs and their corresponding expected outputs.

Supervised learning can be further divided into two main types: classification and regression.

Classification involves predicting a label by identifying the category to which an object belongs based on various parameters.

Regression involves a continuous output prediction by determining the correlations between dependent and independent variables.

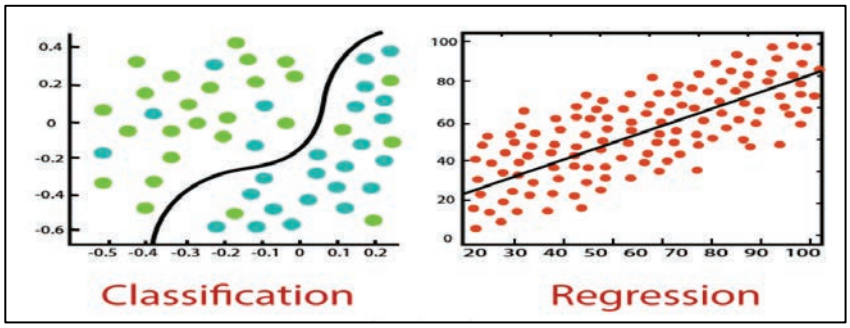


Figure 26. Logistic Regression Algorithm

3.13 Random Forest

The Random Forest algorithm is widely employed in machine learning as it merges the outputs of multiple decision trees to arrive at a single outcome. Its popularity stems from its user-friendliness and versatility, making it suitable for addressing classification and regression issues proficiently.

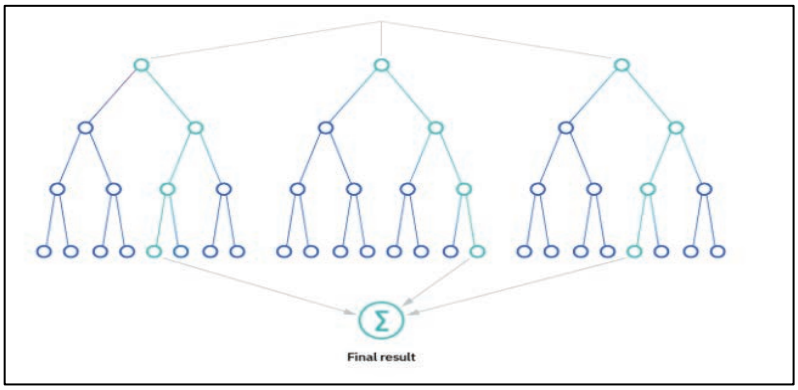


Figure 27. Random Forest Algorithm

Source: (IBM, n.d.)

Random forest algorithms have three primary hyperparameters that must be set prior to training. These hyperparameters consist of the node size, the number of trees, and the number of features to be sampled. Once these parameters are defined, the random forest classifier can effectively address both regression and classification problems (IBM, n.d.).

A classification model was developed for this praxis utilizing a random forest algorithm.

3.14 XGBoost

XGBoost is a widely utilized gradient-boosting algorithm in the field of data science. It is an implementation of gradient boosting that has been specifically designed to be exceptionally efficient, adaptable, and portable.

GBoost operates by assembling multiple weak learners to create a robust learner. A weak learner is merely a machine learning model with minimal improvement compared to random guessing. Nevertheless, the combination of weak learners results in a powerful learner that exhibits significantly improved accuracy.

XGBoost operates by training multiple decision trees, with each tree trained on a specific portion of the data. The predictions from each tree are then amalgamated to create the ultimate prediction (Verma, 2022).

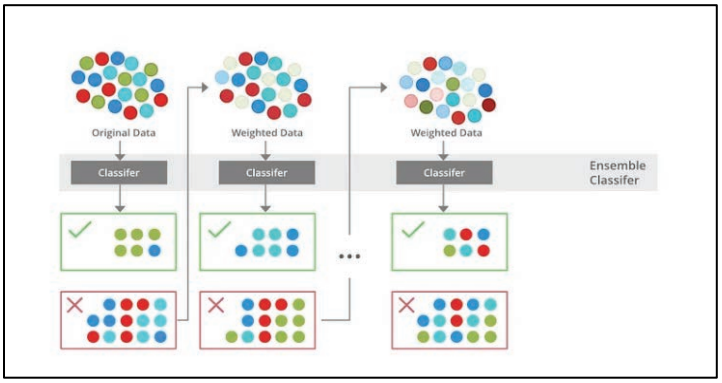


Figure 28. XGBoost Algorithm

3.15 Time Series Data Analysis

Time series data analysis is the process of studying and modeling data points that have been collected or recorded over a period. The objective of time series analysis is to comprehend patterns and trends and make predictions or forecasts using historical data. Additionally, it is employed to identify anomalies in the dataset. In the field of

cybersecurity, time series analysis can be utilized to quantitatively detect anomalies or outliers in data through techniques such as data fitting or forecasting (Kim et al., 2023).

Key steps and concepts in time series data analysis are as follows:

3.15.1 Data Collection

- Collect and record time-stamped data points regularly at specified intervals. Time series data can be classified as univariate (consisting of one variable over time) or multivariate (comprising multiple variables over time).

3.15.2 Data Preprocessing

- Handle missing values and outliers.
- If necessary, data should be resampled or aggregated (such as converting daily data into monthly data).
- Ensure there is a consistent time interval between data points.

3.15.3 Visualization

- One way to analyze time series data and gain insights into trends, seasonality, and patterns is by plotting them. Various types of plots can be used for this purpose, such as line plots, scatter plots, and histograms.

3.15.4 Decomposition

- Break down the time series into its individual components, typically consisting of trend, seasonality, and noise (random fluctuations).
- This step helps in understanding the underlying patterns.

3.15.5 Stationarity

- Most time series models often assume that the data is stationary, indicating that the statistical properties, such as mean and variance, remain constant throughout time.
- Perform tests to determine stationarity and apply appropriate transformations, such as differencing, if necessary.

3.15.6 Model Selection

- Select a suitable time series model by considering the characteristics of your data.
- Common models that are often used in time series analysis include Autoregressive Integrated Moving Average (ARIMA), Seasonal Decomposition of Time Series (STL), and Exponential Smoothing methods.

3.15.7 Model Training

- Fit the selected model to the historical data.
- Estimating model parameters involves determining the autoregressive (AR), integrated (I), and moving average (MA) components.

3.15.8 Model Evaluation

- To assess the performance of the model, it is essential to utilize metrics like Mean Absolute Error (MAE), Mean Squared Error (MSE), or root Mean Squared Error (RMSE).
- Use cross-validation to assess model generalization.

3.15.9 Forecasting

- Make future predictions or forecasts based on the trained model.

- It is important to comprehend the level of uncertainty connected with forecasts, which is frequently represented as prediction intervals.

3.15.10 Model Validation

- Validate the model's forecasts against new, unseen data.
- Monitor the model's performance over time and retrain if necessary.

3.15.11 Visualization of Forecasts

- Plot the actual vs. predicted values to assess how well the model captures the data's patterns.

3.15.12 Interpretation

- Analyze the outcomes, elucidate the importance of model coefficients, evaluate the effect of variables, and gain valuable insights into the behavior of the data.

3.15.13 Decision-Making

- Utilize the knowledge and predictions derived from time series analysis to enhance decision-making processes across various domains, such as business, finance, and more.

Python, equipped with libraries such as pandas, NumPy, statsmodels, and scikit-learn, is frequently employed for conducting time series analysis. The selection of tools and techniques relies upon the distinct attributes of your data and the goals of your analysis (Kim et al., 2023).

3.16 Handling Imbalanced Data

Imbalanced data occurs when one class has a notably larger number of rows or data points compared to the other class. This means there is a significant imbalance in the ratio of value counts between the classes. These datasets are termed as imbalanced datasets,

where one class signifies the majority while the other represents the minority. (Kavish111, 2022).

The imbalance presents a challenge in data categorization. When building a classifier using this kind of data, it tends to show good performance for the majority class but performs poorly for the minority class. Imbalanced data notably affects certain Machine Learning algorithms like Logistic Regression and Support Vector Machine. On the other hand, algorithms such as Random Forest and XGBoost inherently address this issue.

Specific actions must be taken to help algorithms that do not tackle imbalanced data on their own. When faced with imbalanced data, the chosen sampling technique can help. Two sampling techniques are available for handling imbalanced data:

1. Under Sampling
2. Over Sampling

These techniques with their implementation in Python, are further explored in this praxis.

The basic under-sampling technique involves randomly removing examples from the majority class, which is known as 'random under-sampling'. This method is simple to implement and can be effective in certain cases. However, there is still a risk of losing important information that could assist in determining the decision boundary between classes. As such, a more heuristic approach is necessary to choose appropriate examples to keep and identify unnecessary ones for elimination.

Fortunately, there are under-sampling techniques that employ these heuristics.

3.17 Near Miss Under-sampling

This technique chooses data points based on the distance between examples from the majority and minority classes. It consists of three versions, each version considering different neighbors from the majority class.

- Version 1 focuses on including examples that have the shortest average distance to the nearest records of the minority class.
- In Version 2, rows are chosen based on their minimum average distance to the farthest records of the minority class.
- In Version 3, examples from the majority class are kept for each closest record in the minority class.

Version 3 is considered more accurate among these options as it takes into account examples from the majority class that lie on the decision boundary.

3.18 The Two-Sample Z-Test

The two-sample z-test, also known as the independent samples z-test, is a statistical method used to determine if the population means of two different groups are equal or not. This test is commonly applied in analyzing A/B test results. It can be used when the data values are independent and randomly sampled from two normal populations with equal variances in both separate groups. To perform a two-sample z-test, two variables are needed - one to identify the groups being compared and another variable to represent the measurement of interest.

In this study, we have hypothesis number 2 aimed at comparing the effectiveness of ZTA and Perimeter Security in preventing attacks that may result in data breaches or ransomware. The underlying datasets for the two groups differ. The ZTA dataset is

collected from simulated attacks on the ZTA environment, which hosts a three-tier application**,** as described in Section 3.7. To enable ZTA functionality, the ColorTokens agent is deployed on the hosts. The effectiveness of ZTA is measured based on the number of blocked attacks. Another dataset is obtained from a perimeter-based security environment that also features the same three-tier application but with specific configurations for perimeter security, as outlined in Section 3.7. The objective is to determine if there is a difference in mean scores between the ZTA and Perimeter security datasets for the population being evaluated.

To conduct a valid test, a Two-sample z-test, the following assumptions are made:

- The data values must be independent, meaning that the measurements for one observation should not impact the measurements for any other observation.
- It is important to obtain data in each group through a random sample from the population.
- The data in each group should adhere to a normal distribution and have continuous values.
- It is essential that the variances for the two independent groups are equal.

Testing these requirements can be challenging when dealing with very small groups of data.

3.19 Model Validation Process

Before performing machine learning modeling, it is essential to split the data into training and testing datasets. Another concept that is closely related is known as cross-validation. The purpose of cross-validation is to obtain an unbiased estimate of the model's performance on unseen data. It is common for the in-sample error, which

measures the error obtained from running the algorithm on the training dataset, to be overly optimistic and tailored to minimize errors within that specific dataset. Thus, it cannot accurately represent how well our model will perform when applied to new data. Typically, 80% of the data is allocated for training purposes while the remaining portion serves as a test dataset (David, 2019). The training data was used a number of times repeatedly to train the model and validated to determine the accuracy of the model in predicting and preventing attacks. The binary confusion matrix is also used to evaluate performance.

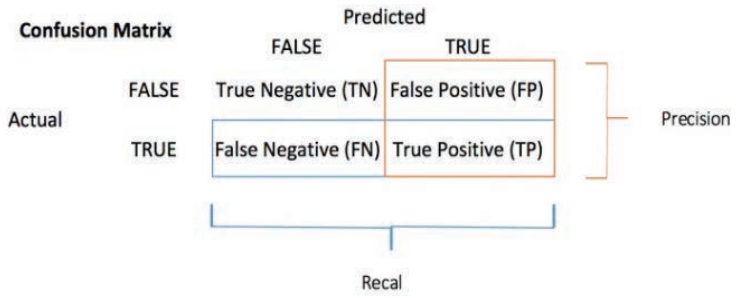


Figure 29. Binary Confusion Matrix

- True Positive (TP): Represents values identified in the model as actual positive.
- False Positive (FP): Represents values that were incorrectly predicted as actual positive, i.e., Negative values predicted as positive. FP is also known as the Type 1 error.
- False Negative (FN): Represents positive values that were incorrectly predicted by the model as negative values. FN is also known as the Type 2 error.

- True Negative (TN): Represents values correctly predicted by the model as actual negative.

The accuracy of a model (through a confusion matrix) is calculated using the given formula below:

$$\text{Accuracy} = \frac{TP+TN}{TP+TN+FN+FP}$$

To conduct performance evaluation, the data inputs were derived from the confusion matrix. The accuracy, recall, precision, and F-Measure are the performance measures utilized in this praxis. The formulas for computing these performance evaluation measures are as follows:

Accuracy	$\frac{TP+TN}{TP+TN+FN+FP}$
Precision	$\frac{TP}{TP+FP}$
Recall	$\frac{TP}{TP+FN}$
F-Measure	$2 \text{ X } Precision \frac{Recall}{Precision} + Recall$

Figure 30. Performance Evaluation Measures

3.20 SHAP (Shapley Additive exPlanations)

SHAP is a game theoretic approach used to explain the output of any machine learning model and measure the contribution made by each feature to that prediction. Each feature is assigned an importance value representing its contribution to the model's output.

The SHAP values illustrate how each feature influences every prediction made. They highlight their relative significance compared to other features and reveal how much the model relies on interactions between different features.

SHAP values provide a widely used and reliable method for obtaining a consistent and unbiased explanation of how each feature influences the prediction made by a model.

These values, which are derived from game theory principles, assign an importance score to each feature within the model. Features with positive SHAP values positively impact the prediction, while those with negative values have a negative impact. The magnitude of the SHAP value indicates the strength of this effect.

One notable advantage of SHAP values is their model-agnostic nature. This means they can be applied to interpret various types of machine learning models, such as linear regression, decision trees, random forests, gradient boosting models, and even neural networks (Awan, 2023).

Chapter 4. Results

4.1 Introduction

This chapter examines the outcomes of the machine learning models developed for this study. It begins by providing a description of the data and explaining its format, as well as the number of records that were available for training the models. The main objective of this chapter is to address research questions by analyzing and validating hypotheses, which serve as the foundation for this study. By considering the previously discussed models and collected data, this chapter will ultimately present its conclusions regarding the results.

The research questions that motivated this study are:

1. Can the Financial Services sector rely on the perimeter security model to protect PII data?
2. Is ZTA a more effective security model for protecting PII?
3. Can ZTA's threat intelligence capabilities be improved by adding anomaly detection features?

The respective hypotheses for the research questions are:

1. The perimeter security model is less effective at preventing cyber threats to cloud workloads and remote connectivity.
2. The ZTA security model protects PII data more effectively than perimeter-based security.
3. Adding anomaly detection features improves ZTA detection capabilities.

The findings of this study are presented in this chapter and implemented following the prescribed methodological approach developed in this praxis.

4.2 Feature Engineering on Simulated Attacks Data

The network traffic data was collected from multiple days of simulated attacks on the two systems (ZTA system and Perimeter system) that were specifically developed for this experiment. Over 300,000 records were generated in these simulated attacks. However, for the purpose of this study, only 10,000 records were analyzed from various scenarios to address the research questions and corresponding hypotheses.

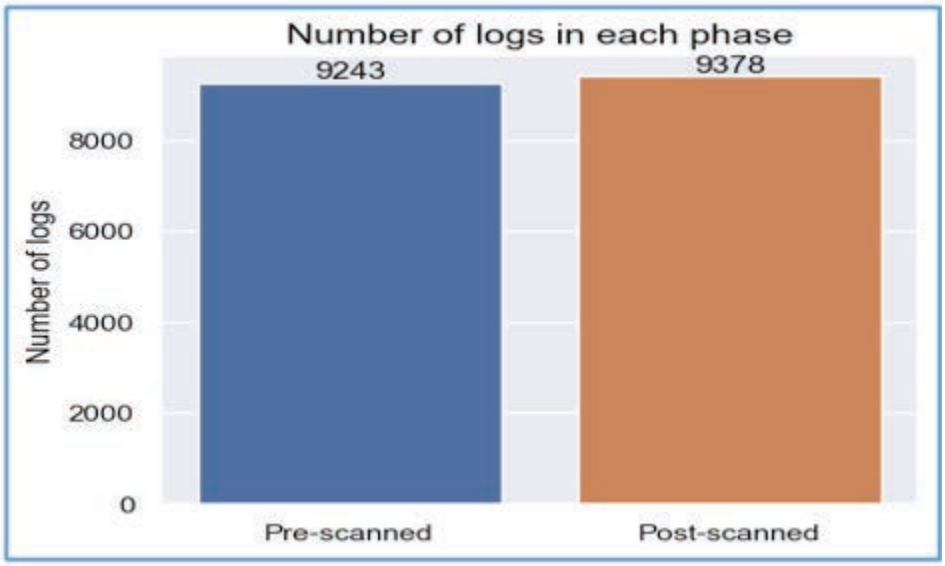
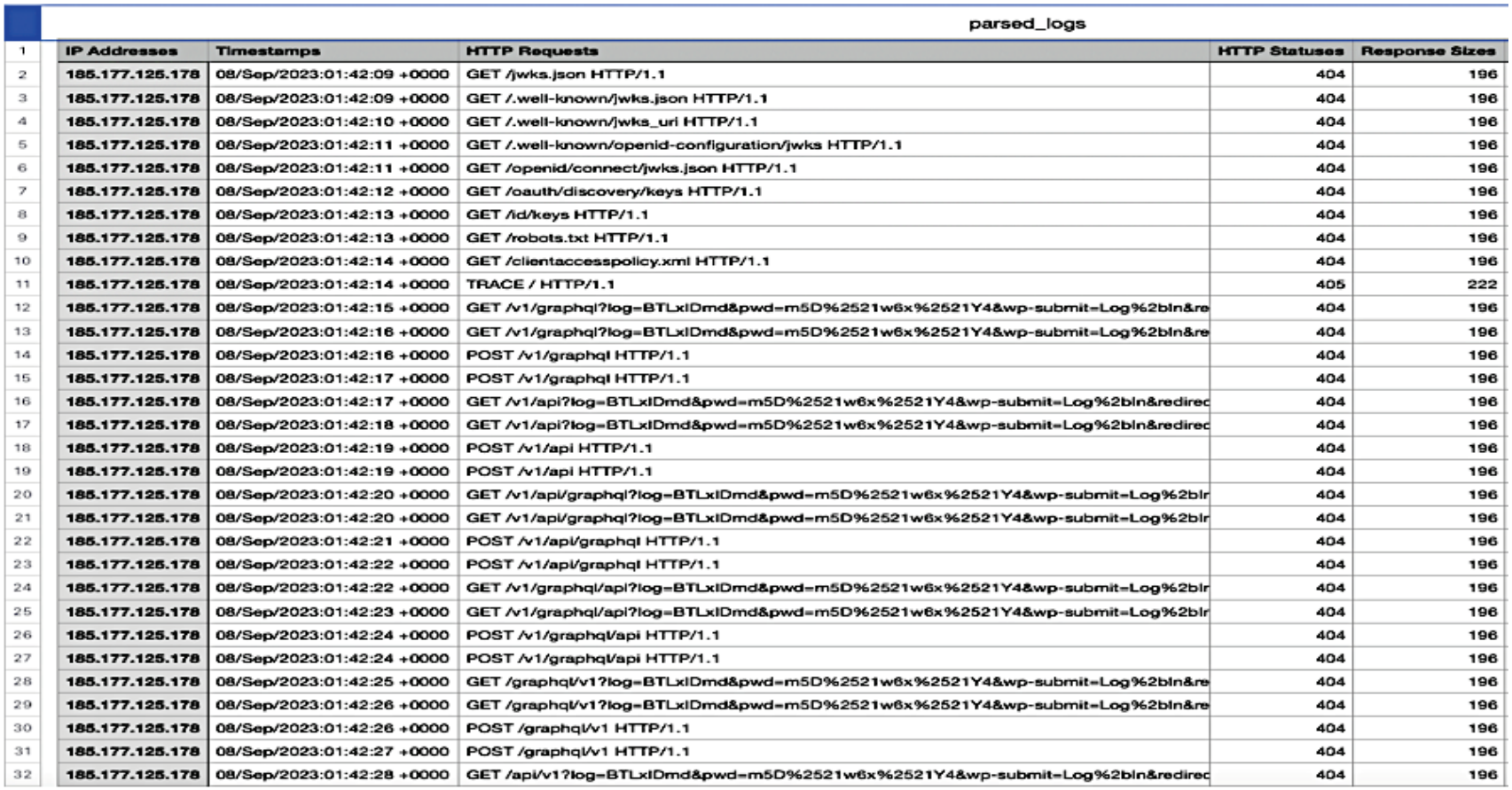


Figure 31. Logs from the Simulated Systems Attacks

Below is the raw data format captured directly from one of the systems:



parsed_logs

	IP Addresses	Timestamps	HTTP Requests	HTTP Statuses	Response Sizes
2	185.177.125.178	08/Sep/2023:01:42:09 +0000	GET /jwks.json HTTP/1.1	404	196
3	185.177.125.178	08/Sep/2023:01:42:09 +0000	GET /.well-known/jwks.json HTTP/1.1	404	196
4	185.177.125.178	08/Sep/2023:01:42:10 +0000	GET /.well-known/jwks_uri HTTP/1.1	404	196
5	185.177.125.178	08/Sep/2023:01:42:11 +0000	GET /.well-known/openid-configuration/jwks HTTP/1.1	404	196
6	185.177.125.178	08/Sep/2023:01:42:11 +0000	GET /openid/connect/jwks.json HTTP/1.1	404	196
7	185.177.125.178	08/Sep/2023:01:42:12 +0000	GET /oauth/discovery/keys HTTP/1.1	404	196
8	185.177.125.178	08/Sep/2023:01:42:13 +0000	GET /id/keys HTTP/1.1	404	196
9	185.177.125.178	08/Sep/2023:01:42:13 +0000	GET /robots.txt HTTP/1.1	404	196
10	185.177.125.178	08/Sep/2023:01:42:14 +0000	GET /clientaccesspolicy.xml HTTP/1.1	404	196
11	185.177.125.178	08/Sep/2023:01:42:14 +0000	TRACE / HTTP/1.1	405	222
12	185.177.125.178	08/Sep/2023:01:42:15 +0000	GET /v1/graphql?log=BTLxlDmd&pwd=m5D%2521w6x%2521Y4&wp-submit=Log%2bln&re	404	196
13	185.177.125.178	08/Sep/2023:01:42:16 +0000	GET /v1/graphql?log=BTLxlDmd&pwd=m5D%2521w6x%2521Y4&wp-submit=Log%2bln&re	404	196
14	185.177.125.178	08/Sep/2023:01:42:16 +0000	POST /v1/graphql HTTP/1.1	404	196
15	185.177.125.178	08/Sep/2023:01:42:17 +0000	POST /v1/graphql HTTP/1.1	404	196
16	185.177.125.178	08/Sep/2023:01:42:17 +0000	GET /v1/api?log=BTLxlDmd&pwd=m5D%2521w6x%2521Y4&wp-submit=Log%2bln&redirec	404	196
17	185.177.125.178	08/Sep/2023:01:42:18 +0000	GET /v1/api?log=BTLxlDmd&pwd=m5D%2521w6x%2521Y4&wp-submit=Log%2bln&redirec	404	196
18	185.177.125.178	08/Sep/2023:01:42:19 +0000	POST /v1/api HTTP/1.1	404	196
19	185.177.125.178	08/Sep/2023:01:42:19 +0000	POST /v1/api HTTP/1.1	404	196
20	185.177.125.178	08/Sep/2023:01:42:20 +0000	GET /v1/api/graphql?log=BTLxlDmd&pwd=m5D%2521w6x%2521Y4&wp-submit=Log%2bln	404	196
21	185.177.125.178	08/Sep/2023:01:42:20 +0000	GET /v1/api/graphql?log=BTLxlDmd&pwd=m5D%2521w6x%2521Y4&wp-submit=Log%2bln	404	196
22	185.177.125.178	08/Sep/2023:01:42:21 +0000	POST /v1/api/graphql HTTP/1.1	404	196
23	185.177.125.178	08/Sep/2023:01:42:22 +0000	POST /v1/api/graphql HTTP/1.1	404	196
24	185.177.125.178	08/Sep/2023:01:42:22 +0000	GET /v1/graphql/api?log=BTLxlDmd&pwd=m5D%2521w6x%2521Y4&wp-submit=Log%2bln	404	196
25	185.177.125.178	08/Sep/2023:01:42:23 +0000	GET /v1/graphql/api?log=BTLxlDmd&pwd=m5D%2521w6x%2521Y4&wp-submit=Log%2bln	404	196
26	185.177.125.178	08/Sep/2023:01:42:24 +0000	POST /v1/graphql/api HTTP/1.1	404	196
27	185.177.125.178	08/Sep/2023:01:42:24 +0000	POST /v1/graphql/api HTTP/1.1	404	196
28	185.177.125.178	08/Sep/2023:01:42:25 +0000	GET /graphql/v1?log=BTLxlDmd&pwd=m5D%2521w6x%2521Y4&wp-submit=Log%2bln&re	404	196
29	185.177.125.178	08/Sep/2023:01:42:26 +0000	GET /graphql/v1?log=BTLxlDmd&pwd=m5D%2521w6x%2521Y4&wp-submit=Log%2bln&re	404	196
30	185.177.125.178	08/Sep/2023:01:42:26 +0000	POST /graphql/v1 HTTP/1.1	404	196
31	185.177.125.178	08/Sep/2023:01:42:27 +0000	POST /graphql/v1 HTTP/1.1	404	196
32	185.177.125.178	08/Sep/2023:01:42:28 +0000	GET /api/v1?log=BTLxlDmd&pwd=m5D%2521w6x%2521Y4&wp-submit=Log%2bln&redirec	404	196

Figure 32. Network Traffic Raw Data

4.3 Simulation Attacks Results Analysis

This section of the analysis will concentrate on the validation of research questions 1 and 2, along with their corresponding hypotheses.

The following are specific methods that were utilized to analyze data from the system and potential attack patterns on each system and measure the system controls effectiveness at identifying or preventing attacks.

4.4 Time Series Analysis

The time series analysis was performed to understand network traffic patterns over time and packet delivery to target systems. Below is a plot of traffic volume, which identifies peak times and displays anomalies. The simulated attack was created to infiltrate the computers and access the PII data that was stored on both systems.

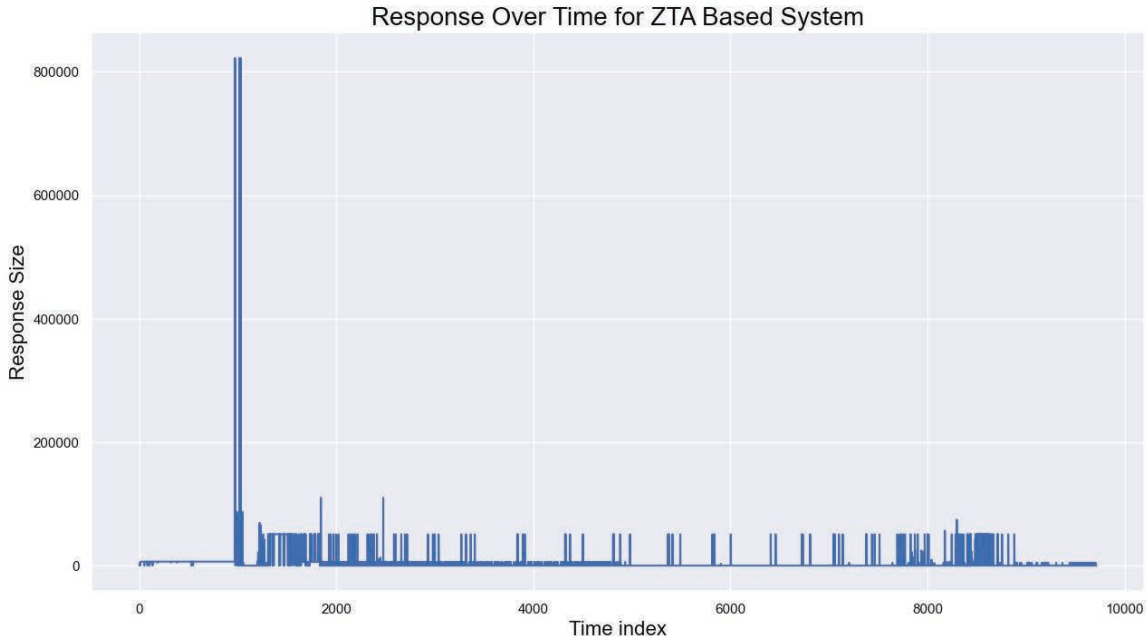


Figure 33. ZTA Based System with Policy Running

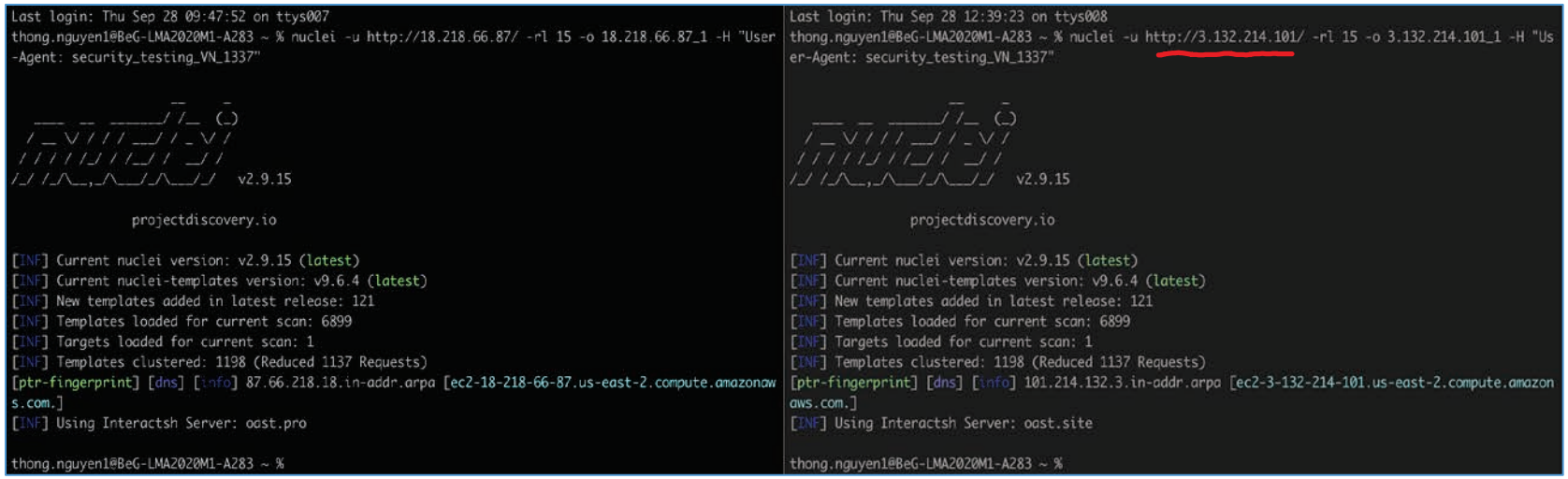


Figure 34. ZTA Server Image



Figure 35. ZTA Policy Enforcement

The second image (Figure 35) from the server displays the identified attacker IP. Since this IP is not authorized to access the system, immediate action is taken to block the access. The corresponding tcpdump log revealed an HTTP Event Header 403, indicating that the server has received the request but refused to authorize it.

During multiple scans of the ZTA-based system, observation was made of a consistent pattern or recurring results in the behavior of the system. These findings could be attributed to the security measures and access controls that ZTA implements.

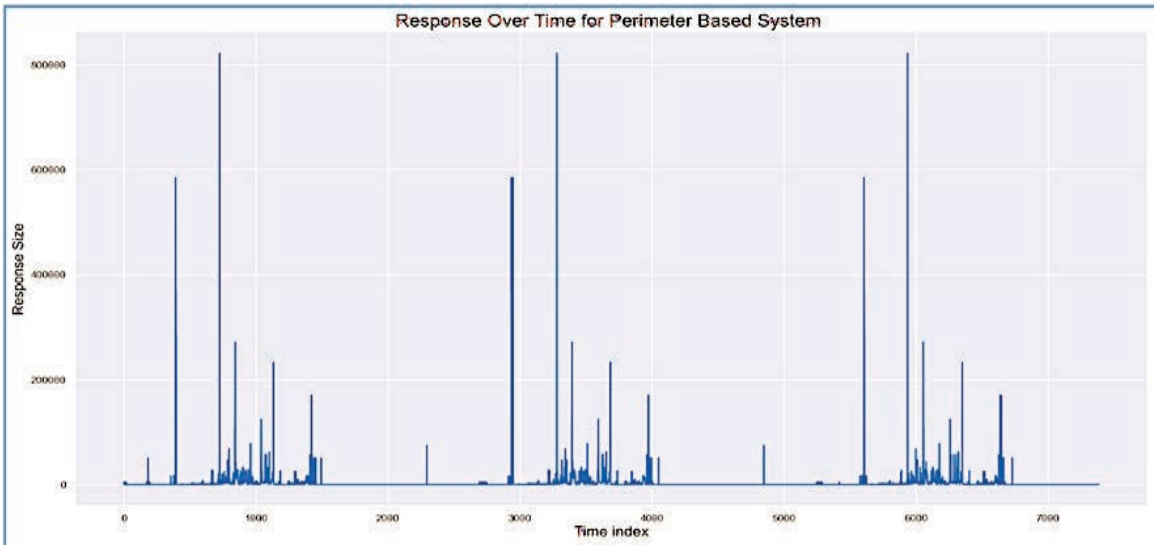


Figure 36. Perimeter-Based Security System

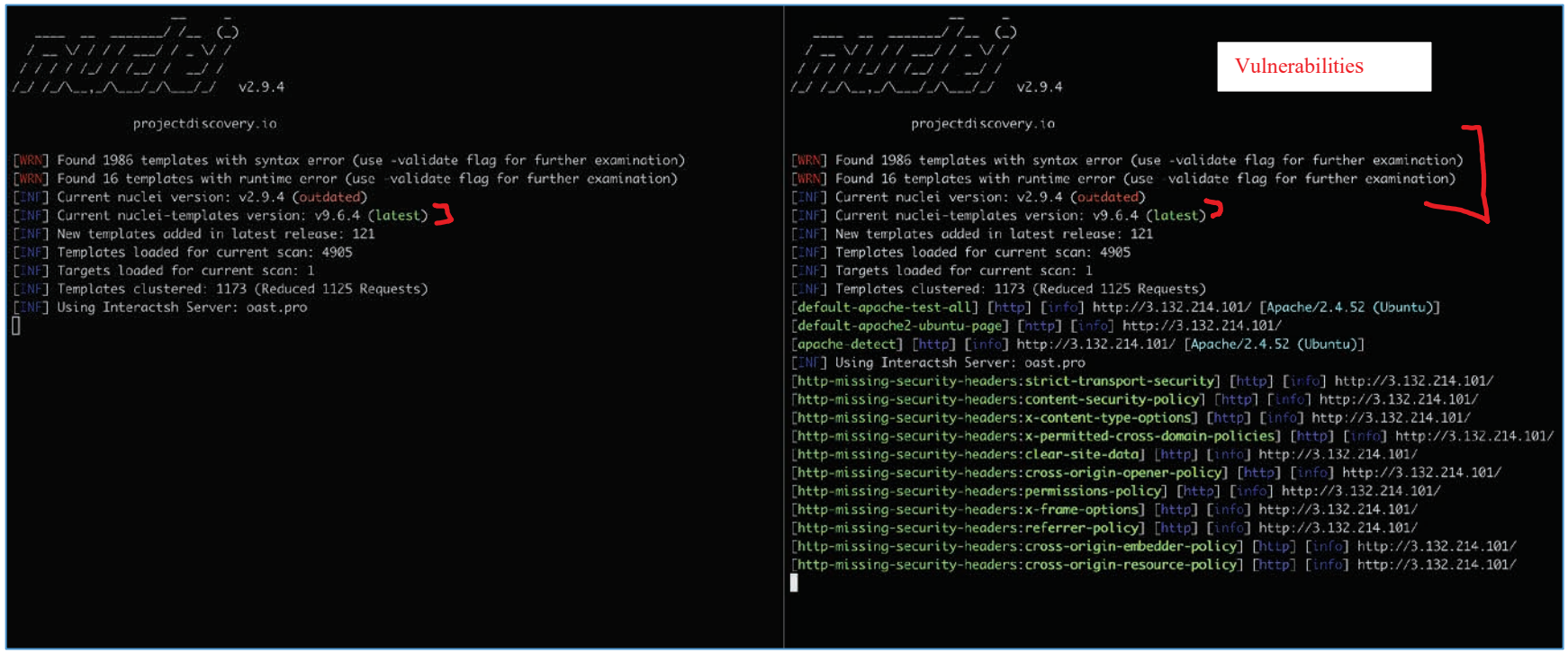


Figure 37. Perimeter Security System

The Perimeter-based system (Figure 36) displays significant response sizes that are linked to the duration of its operation. Although some connections were unsuccessful, the successful ones provided insights into open ports or vulnerabilities inside the system, as shown in Figure 37.

The three highest response sizes observed in Figure 36 also align with the HTTP Event Header 200, which confirms a successful connection request by indicating a successful status response code. This could also imply that in a non-ZTA environment, there were data-intensive activities or interactions with sizable response payloads.

4.5 Conclusion

The discrepancies observed between the ZTA-based system and the Perimeter-based system can be attributed in part to the effects of ZTA deployment. The implementation of ZTA's security policies and access restrictions may have caused changes in data transmission and processing within the system, thus impacting response size patterns. To have a more comprehensive evaluation of the impact of ZTA on the system, it is crucial to understand the precise ways it has influenced data interactions and response sizes. This praxis did not cover these discrepancies in detail.

4.6 Request Analysis

This praxis also compared and analyzed the effect of access request methods on the system for each implementation. The “Protocol” column grouped the data to analyze the distribution of different types of network protocols (e.g., HTTP, HTTPS, TCP, UDP).

A calculation of the count, average length, or response time for each protocol was performed, and the results were analyzed as follows:

Two methods of more interest to this praxis based on research questions were GET and POST, which were analyzed to identify any malicious activities that could potentially lead to security breaches based on their usage, as noted in Table 4.

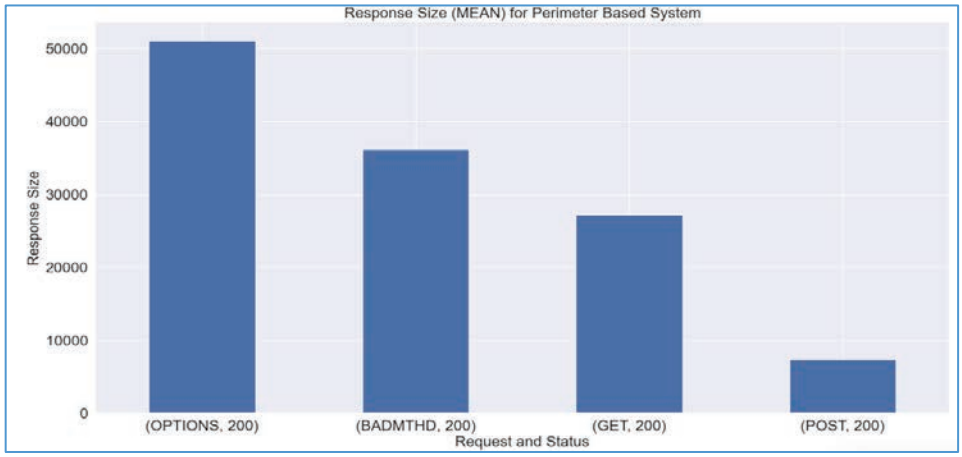


Figure 38. Response Methods for Perimeter Security Based System

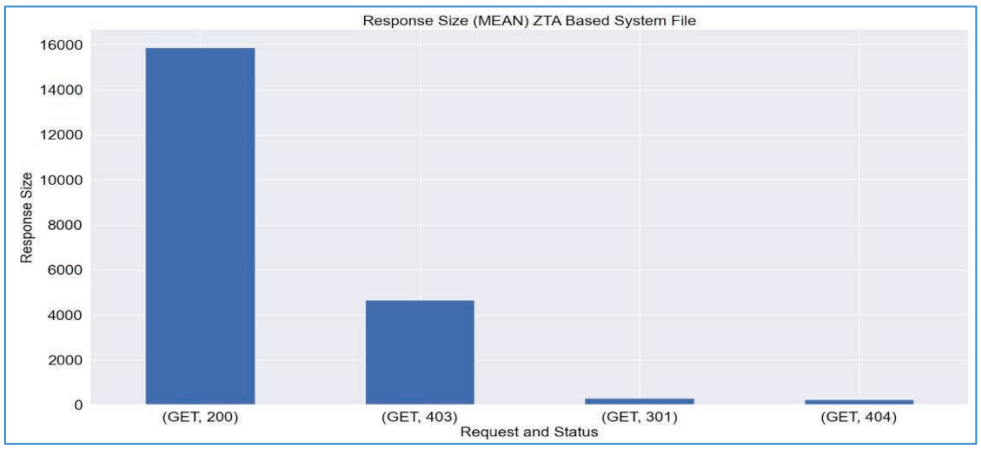


Figure 39. ZTA Response Methods for Security Based System

In Figure 38. Response Methods for Perimeter Security Based System, the Perimeter security-based system received numerous successful responses with a status code of 200, indicating that various scanning methods were successful in accessing the system. Conversely, the ZTA security-based system only permitted traffic from the jump box (Figure 40) to successfully complete the GET method. It is important to note that this

specific IP address has been granted explicit access to the system through port 22 (Figure 40.ZTA Policy Management Dashboard). Any other attempts to access the ZTA security-based system using different methods were blocked (Table 3). The total request responses for both systems varied significantly, with 16,000 for ZTA and 50,000 for Perimeter. This discrepancy can be attributed to a large number of requests being blocked by the ZTA security-based system.

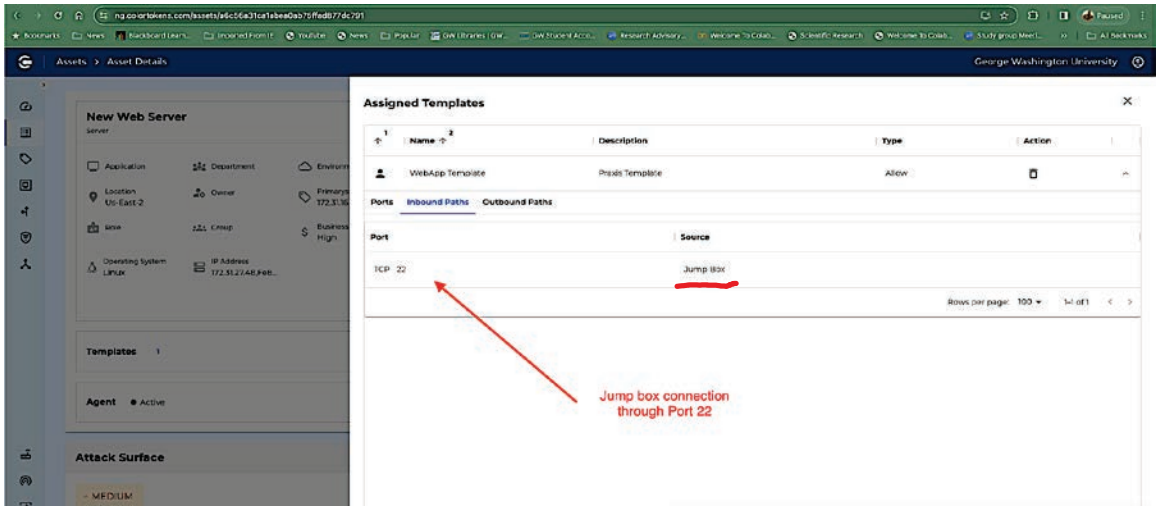


Figure 40: Policy Management Dashboard

4.7 Additional Observation

Reduction in POST Requests:

The log entries in the ZTA security-based system showed a lower number of HTTP POST requests when compared to the Perimeter security-based system. This indicates that ZTA may have had an impact on the frequency of POST requests within the network or system. The decrease in POST requests could be attributed to improved security measures and access controls that were implemented as part of the ZTA approach. The

strict authorization and authentication policies resulting from ZTA may have limited certain types of POST requests or actions from unauthorized users.

4.8 Conclusion

The analysis highlights the effectiveness of ZTA security controls in preventing unauthorized requests. It suggests that implementing ZTA has resulted in a decrease in log entries that contain POST requests. This finding underscores the impact of ZTA on network security and access control, as it reduces specific types of HTTP POST requests within the network or system.

4.9 TCP Flags Analysis

Tcpdump is a middleware computer program that serves as a data-network packet analyzer, running through a command line interface. This software enables users to observe the transmission and reception of TCP/IP and various other packets over the network connected to the computer.

Monitoring TCP flags is beneficial because it provides cybersecurity professionals with a deeper comprehension of network activities. For instance, an unusually high volume of TCP SYN flags could signify a denial-of-service attack, where the attacker initiates multiple connections to a server using a disguised IP address without completing the connection. Consequently, servers allocate resources to handle these partially opened connections, which can drain enough resources to render the system unresponsive to legitimate traffic (Kapustin & Paulauskas, 2023).

Moreover, using specific TCP flag inflows can help predict an anomaly activity in the network. To illustrate this point further, an excessive number of ACK flags transmitted to a monitored network might indicate a TCP ACK scan. In this scenario, the

attacker sends ACK flags and evaluates whether firewall settings block ports based on received RST flags in TCP segments. Furthermore, if there is an abundance of received RST+ACK flags, it may suggest a TCP SYN scan is taking place. Additionally, an excessive number of flow records without any TCP flags set could imply a Null scan. The study delved into TCP flags to create a predictive model that enhances anomaly detection capabilities. This addition complements the current ZTA threat intelligence feature, which relies on signature detection, thereby reinforcing this functionality. This aspect of the study introduces a novel approach to threat intelligence (Kapustin & Paulauskas, 2023).

Table 5. TCP Flags Table

Flag	Description
SYN (S)	It is used for the initial three-way handshake, in which both parties generate the initial sequence numbers.
URG (U)	This suggests that priority should be given to treating the data over other types of data.
ACK (A)	This phrase is used to verify if the data packets have been successfully received.
PSH (P)	Enables an application to immediately terminate transmission of data, without the need to wait for the entire TCP segment to be filled.
FIN (F)	The FIN bit is used to terminate the TCP connection, which operates in full duplex mode. It is essential for both the sender and receiver to employ the FIN bit to conclude the connection. This method serves as the standard approach for terminating connections by both parties involved.
RST (R)	The flag is used to reset the connection, prompting the host to immediately terminate it upon receiving the signal. This method is exclusively employed in cases of irreparable errors and is not a standard means of concluding a TCP connection.

The activity logs for both systems were analyzed to study the tcpdump log flags. A machine learning models were utilized for this analysis. The data was organized based

on the “Flags” column to examine the distribution of various communication flags (e.g., [.], [P.], etc.). This analysis revealed patterns and frequencies of these flags, which can be valuable for security analysis purposes.

```
1  # CHi-squared test for Request column
2  chi_squared_test(df1=pdf_post['Flag_Data'], df2=pdf_pre['Flag_Data'])
3
✓  0.0s

Chi-squared statistic: 2.778443255329873
p-value: 0.8360964354319921
accept null hypothesis
```

Figure 41.CHi-Squared Test

After comparing TCP flag counts and types from both the ZTA security-based and Perimeter security-based systems, this study found no significant differences before and after implementing the ZTA function. This implies that the simulated attacks on both systems led to a similar count and types of TCP flags raised in both systems. As such, this information cannot be used as a reliable factor in identifying an anomaly or suspicious act.

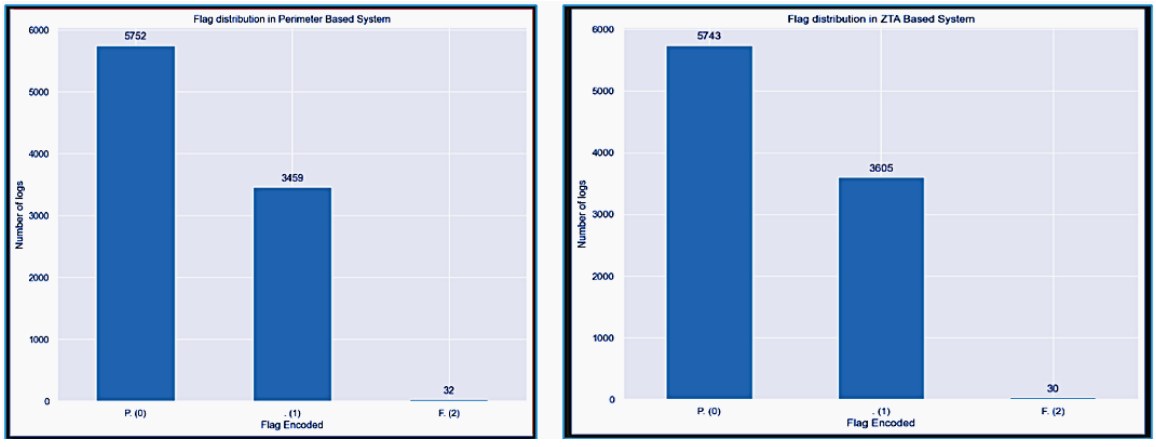


Figure 42. Flags Distributions Between the Two Systems

Both of the above images present similar information, which was considered irrelevant in determining the presence of suspicious activities in the network despite originating from two different systems with distinct security configurations.

4.10 Source and Destination Analysis

The praxis examined the source and destination information in order to identify common pairs of communication. It also investigated whether there were any unusual or unexpected source-destination pairs, which could potentially indicate security issues or misconfigurations. The ZTA agent that was utilized had been configured to permit traffic only through certain ports, while restricting access to any other ports that have not been explicitly authorized in the policy template. This analysis was created with the purpose of detecting any abnormal patterns by scrutinizing the source and destination data of incoming and outgoing packets within the network.



Figure 43.Chi-Squared Test

After conducting the chi-squared test (Figure 43) on the “"Source” and “Destination” columns, an observation was made on the significant differences in both variables before and after implementing ZTA.

4.11 Window Size and Length Analysis

The TCP window size field is responsible for managing data flow and can be scaled to accommodate data flow.

To comprehend the window size employed in communications, one should analyze the “Window” column. This analysis can offer valuable insights into network performance and detect abnormal activities.

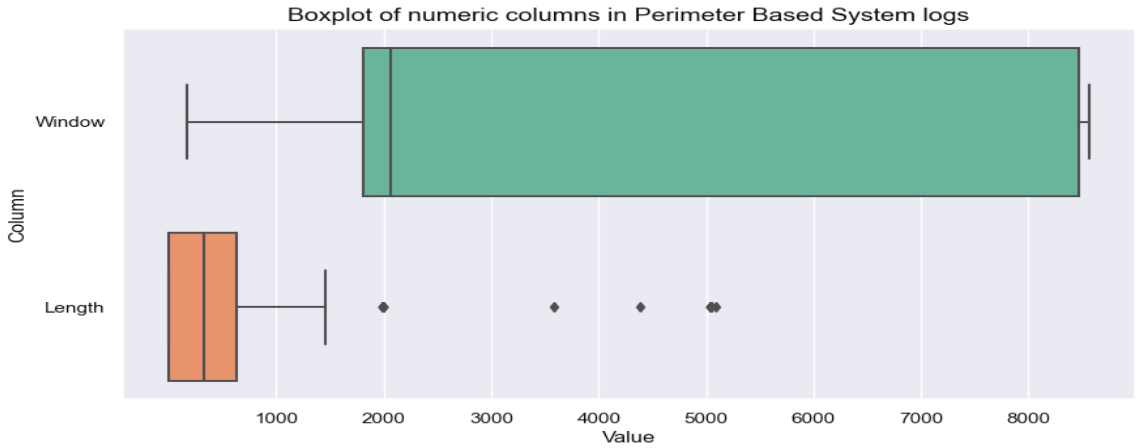


Figure 44. Box Plot Analysis of Window and Length of Packages on Perimeter System

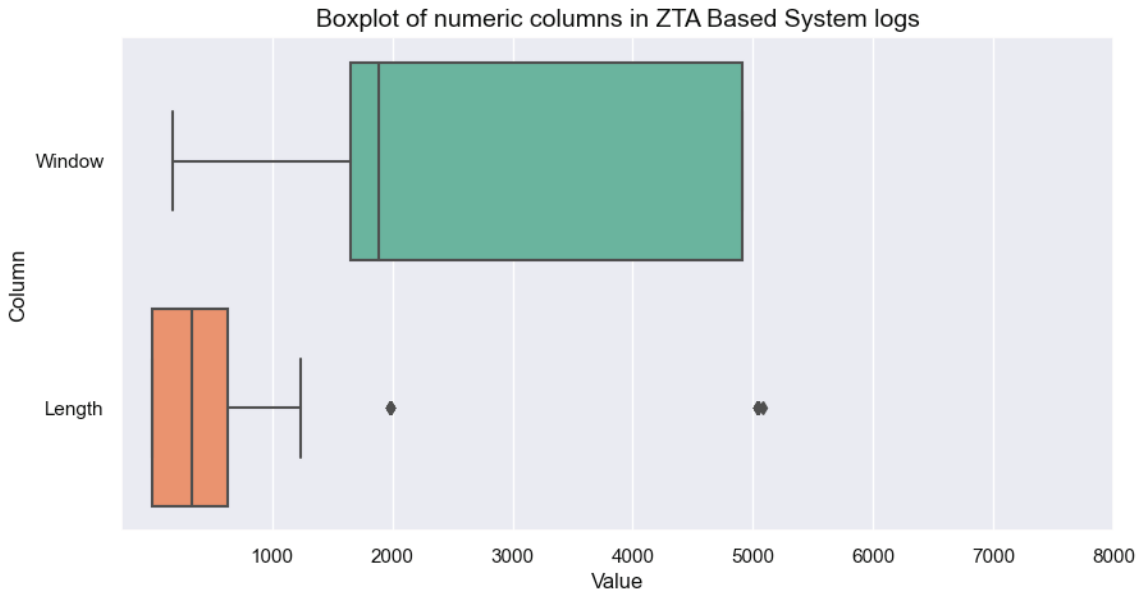


Figure 45. Box Plot Analysis Window and Length pf Packages on ZTA System Logs

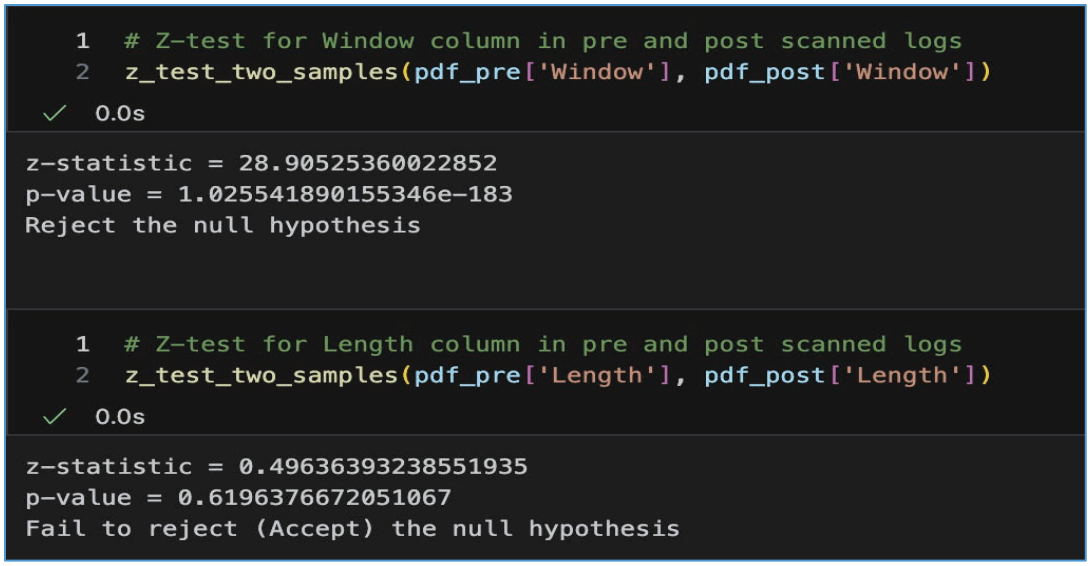


Figure 46. Z-Test Two Sample Analysis

The above analysis demonstrates a notable distinction between ZTA and Perimeter-based security system files. A z-test was employed to investigate whether the distribution of the “Length” and “Window” columns differed before and after activating the ZTA agent on the servers.

The results indicate that the “Length” columns are identical, leading us to reject the null hypothesis for these two datasets. Conversely, there are significant differences observed in the 'Window' columns between them. Prior to scanning, the data in the “Window” column exhibits wide dispersion, with higher mean and third quartile values compared to post-scanning. It appears that implementing ZTA has led to a reduction in the size of window parameters up to a specific limit. As such, this information could be used in the identification of potential anomaly activities that may be cybersecurity related.

4.12 HTTP Status Code

A Chi-Square analysis over the HTTP Status code column was conducted before and after integrating the ZTA agent dataset. The results of the analysis indicate that there is a disparity in the distribution of status codes between the ZTA-based system and the Perimeter-based system. Both p-values were found to be ≤ 0.05, leading to the rejection of the null hypothesis (Figure 43).

An analysis like the one mentioned above was conducted on the Sequence column with the aim of identifying patterns or data sequencing issues that might suggest a malicious act. This analysis also resulted in rejecting the null hypothesis. (Figure 48).



Figure 47. HTTP Status Code Analysis



Figure 48. Communication Sequence Analysis

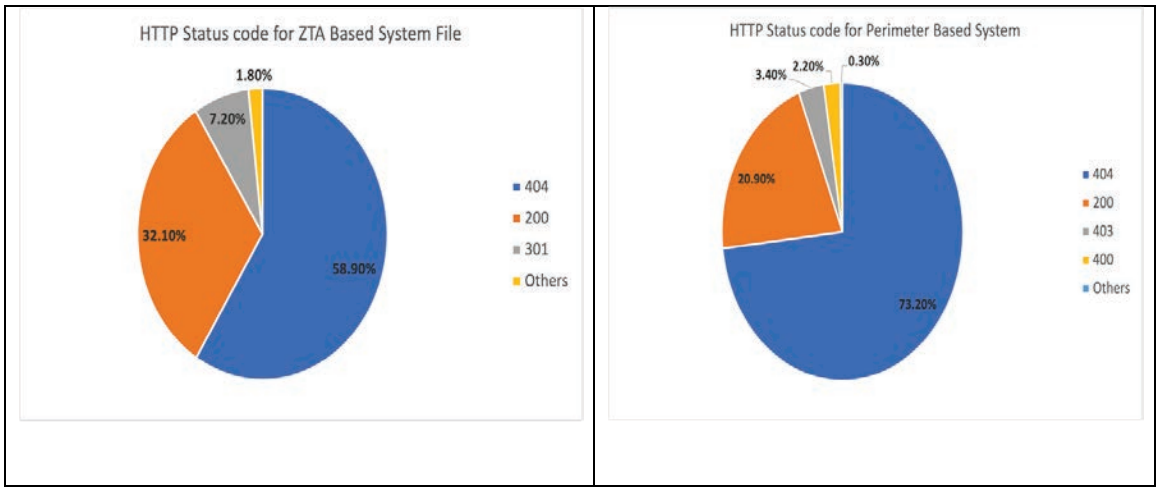


Figure 49. HTTP Status Code for Perimeter Vs. ZTA Based System

Based on observation, the lack of the ZTA function led to nearly 80% of error statuses, comprising mainly 404 error codes (73%) and a combination of 403 and 400 error codes (5%). Only about one-fifth of the total were successful status codes. However, with the implementation of the ZTA function, there was a noticeable decrease in error statuses from 80% to around 60%. At the same time, successful code proportions increased by over 10%. These results unequivocally showcase that ZTA can significantly reduce logged errors. These findings also suggest that as ZTA grants users, devices, and applications explicit access, system access is based on the level of trust validated before it is granted. If the specified trust thresholds are not met, access will be denied. As a result, a considerable amount of network traffic is filtered out, leading to a decrease in the number of access error codes. Error codes also imply a deliberate attempt to scan for vulnerable hosts and exploit them.

Success Rate: On the other hand, only about one-fifth (20%) of the network/system interactions were categorized as successful, meaning they likely returned a "200 OK" status code. Successful interactions typically represent valid and expected user actions or network communications. Again, this can be attributed to ZTA access being restricted to

only authorized subjects by applying the principles of Never trust, always verify, and least privilege.

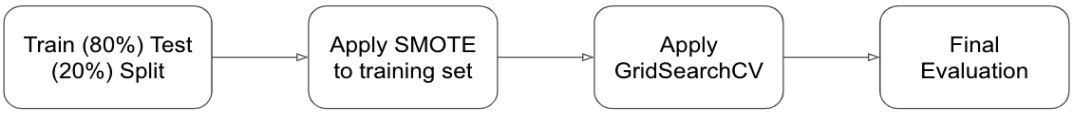
Error Status Reduction: The implementation of Zero Trust Architecture (ZTA) resulted in a significant decrease in the occurrence of error status codes, dropping from 80% to approximately 60%. This small study provides statistical evidence that the security measures and access controls implemented with ZTA effectively reduced the number of unauthorized or problematic interactions within the network or system.

Increased Success Rate: Alongside the decrease in error status codes, there was a notable increase of over 10% in the proportion of successful interactions. This indicates that ZTA not only diminished security-related errors but also improved the efficiency and success rate of legitimate interactions, resulting in a more dependable and user-friendly network or system.

4.13 Anomaly Detection Model

Three machine-learning models will be employed for this predictive model: Logistic Regression, Random Forest, and XGBoost. Since the distribution of each flag is not the same, it results in an imbalance problem. Therefore, **SMOTE** will be used to address this problem.

The prepared data step is as follows:



The same process mentioned above will be used for each model in every system. The F1 score will serve as the final metric for evaluating this problem.

To address the issue of overfitting with the dataset, this praxis utilized GridSearchCV. However, despite this effort, all models continued to experience overfitting problems in detecting label 2 (F.). On the other hand, all the models performed well for the other two labels and encountered fewer instances of overfitting. Among these models, XGBoost displayed superior performance on both systems the F1 scores ranging from 79% to 81%. When applying the ZTA-based system data to these models, XGBoost outperformed the pre-anomaly detection data by an additional 2% in terms of the F1-score. This observation supports the notion that incorporating an anomaly detection function in the ZTA threat intelligence function can enhance its capabilities to detect anomaly performance and security issues. Please review the results below for the models' performance results:

Note: Use the F1-score at the macro avg row for performance measurement.

Table 6. Logistic Regression Anomaly Detection Model Evaluation Confusion Matrix for Perimeter-Based System

Logistic Regression Perimeter Based System									
Evaluation of Training Dataset					**Evaluation of Test Dataset**				
	Precision	**Recall**	**F1**	**Support**		**Precision**	**Recall**	**F1**	**Support**
0	1	0.99	**0.99**	4601	0	1	0.98	**0.99**	1151
1	1	0.92	0.96	4601	1	1	0.91	0.95	692
2	0.96	1	0.96	4601	2	0.07	1	0.12	6
Accuracy			0.97	13803	**Accuracy**			0.95	1849
Marco Avg	0.97	0.97	**0.97**	13803	**Marco Avg**	0.69	0.96	**0.69**	1849
Weighted Avg	0.97	0.97	0.97	13803	**Weighted Avg**	1	0.95	0.97	1849

Logistic Regression Perimeter Based System							
Evaluation of Training Dataset				**Evaluation of Test Dataset**			
Confusion Matrix:				**Confusion Matrix:**			
	Predicted 0	**Predicted 1**	**Predicted 2**		**Predicted 0**	**Predicted 1**	**Predicted 2**
Actual 0	4540	1	60	**Actual 0**	1132	0	19
Actual **1**	2	4227	372	**Actual 1**	0	627	65
Actual 2	0	0	4601	**Actual 2**	0	0	6

Table 7. Logistic Regression Anomaly Detection Model Evaluation Confusion Matrix for ZTA-Based System

Logistic Regression ZTA-Based System									
Evaluation of Training Dataset					**Evaluation of Test Dataset**				
	Precision	**Recall**	**F1**	**Support**		**Precision**	**Recall**	**F1**	**Support**
0	1	1	**1**	4594	0	1	0.99	**1**	1149
1	1	0.92	**0.96**	4594	1	1	0.92	0.96	721
2	0.92	1	0.96	4594	2	0.08	1	0.15	6
Accuracy			0.97	13782	Accuracy			0.96	1876
Marco Avg	0.97	0.97	**0.97**	13782	Marco Avg	0.69	0.97	**0.7**	1876
Weighted Avg	0.97	0.97	0.97	13782	Weighted Avg	1	0.96	0.98	1876
Confusion Matrix:					**Confusion Matrix:**				
	Predicted 0	**Predicted 1**	**Predicted 2**			**Predicted 0**	**Predicted 1**	**Predicted 2**	
Actual 0	4574	0	20		**Actual 0**	1141	0	8	
Actual 1	0	4231	363		**Actual 1**	1	661	59	
Actual 2	0	0	4594		**Actual 2**	0	0	6	

With the ZTA-based system turning on, the Logistic Regression seems to have less probability of misclassifying class 2 (F.) in the test dataset (on the right-side figures)

Table 8. Random Forest Model Evaluation Confusion Matrix for Perimeter-Based System

Random Forest for Perimeter Based System

Evaluation of Training Dataset

	Precision	Recall	F1	Support
0	1	1	**1**	4601
1	1	0.95	0.98	4601
2	0.96	1	0.98	4601
Accuracy			0.98	13803
Marco Avg	0.98	0.98	**0.98**	13803
Weighted Avg	0.98	0.98	0.98	13803

Confusion Matrix:

	Predicted 0	Predicted 1	Predicted 2
Actual 0	4601	0	0
Actual 1	0	4385	214
Actual 2	0	0	4597

Evaluation of Test Dataset

	Precision	Recall	F1	Support
0	1	1	**1**	1151
1	1	0.94	0.97	692
2	0.13	1	0.23	6
Accuracy			0.98	1849
Marco Avg	0.71	0.98	**0.73**	1849
Weighted Avg	1	0.98	0.99	1849

Confusion Matrix:

	Predicted 0	Predicted 1	Predicted 2
Actual 0	1151	0	0
Actual 1	0	651	41
Actual 2	0	0	6

Table 9. Random Forest Model Evaluation Confusion Matrix for ZTA-Based System

Random Forest for ZTA-Based System

Evaluation of Training Dataset

	Precision	Recall	F1	Support
0	1	1	**1**	4594
1	1	0.92	0.96	4594
2	0.92	1	0.96	4594
Accuracy			0.97	13782
Marco Avg	0.97	0.97	**0.97**	13782
Weighted Avg	0.97	0.97	0.97	13782

Evaluation of Test Dataset

	Precision	Recall	F1	Support
0	1	0.99	1	1149
1	1	0.92	0.96	721
2	0.08	1	0.15	6
Accuracy			0.96	1876
Marco Avg	0.69	0.97	0.7	1876
Weighted Avg	1	0.96	0.98	1876

Random Forest for ZTA-Based System			
Evaluation of Training Dataset			
Confusion Matrix:			
	Predicted 0	**Predicted 1**	**Predicted 2**
Actual 0	4574	0	20
Actual 1	0	4231	363
Actual 2	0	0	4594

Evaluation of Test Dataset			
Confusion Matrix:			
	Predicted 0	**Predicted 1**	**Predicted 2**
Actual 0	1141	0	8
Actual 1	1	661	59
Actual 2	0	0	6

With the ZTA-based system turning on, the random forest does not perform as well as when it is turned off.

Table 10. XGBoost Model Evaluation Confusion Matrix for Perimeter-Based System

XGBoost for Perimeter-Based System				
Evaluation of Training Dataset				
	Precision	**Recall**	**F1**	**Support**
0	1	1	**1**	4601
1	1	0.99	0.99	4601
2	0.99	1	0.99	4601
Accuracy			1	13803
Marco Avg	1	1	**1**	13803
Weighted Avg	1	1	1	13803

Evaluation of Test Dataset				
	Precision	**Recall**	**F1**	**Support**
0	1	1	**1**	1151
1	1	0.98	0.99	692
2	0.24	0.67	0.35	6
Accuracy			0.99	1849
Marco Avg	0.64	0.88	**0.78**	1849
Weighted Avg	1	0.99	0.99	1849

Confusion Matrix:			
	Predicted 0	**Predicted 1**	**Predicted 2**
Actual 0	4601	0	0
Actual 1	0	4553	48
Actual 2	0	0	4591

Confusion Matrix:			
	Predicted 0	**Predicted 1**	**Predicted 2**
Actual 0	1151	0	0
Actual 1	0	679	13
Actual 2	0	2	4

Table 11. XGBost Model Evaluation Confusion Matrix for ZTA-Based System

XGBoost for ZTA-Based System

Evaluation of Training Dataset

	Precision	Recall	F1	Support
0	1	1	**1**	4594
1	1	0.99	1	4594
2	0.99	1	1	4594
Accuracy			1	13782
Marco Avg	1	1	**1**	13782
Weighted Avg	1	1	1	13782

Evaluation of Test Dataset

	Precision	Recall	F1	Support
0	1	1	**1**	1149
1	1	0.99	0.99	721
2	0.33	0.67	0.44	6
Accuracy			0.99	1876
Marco Avg	0.78	0.89	**0.81**	1876
Weighted Avg	1	0.99	1	1876

Confusion Matrix:

	Predicted 0	Predicted 1	Predicted 2
Actual 0	4594	0	0
Actual 1	0	4564	30
Actual 2	0	0	4588

Confusion Matrix:

	Predicted 0	Predicted 1	Predicted 2
Actual 0	1149	0	0
Actual 1	1	713	8
Actual 2	0	2	4

Results show that XGBoost algorithm performs better among the three algorithms used in this praxis. Consistently, the train and test anomaly detection result for both (ZTA and Perimeter) systems performed better than the anomaly detection model for other algorithms. However, when we look at the best-performing algorithm in this experiment (XGBoost), we can see that the difference between the before and after ZTA function has been applied to the training dataset, and the anomaly detection enhancement in the threat intelligence is not statistically significant, which implies that the anomaly detection

capabilities will equally improve both systems' detection capabilities but not by a significant amount.

4.14 SHAP (Shapley Additive exPlanations)

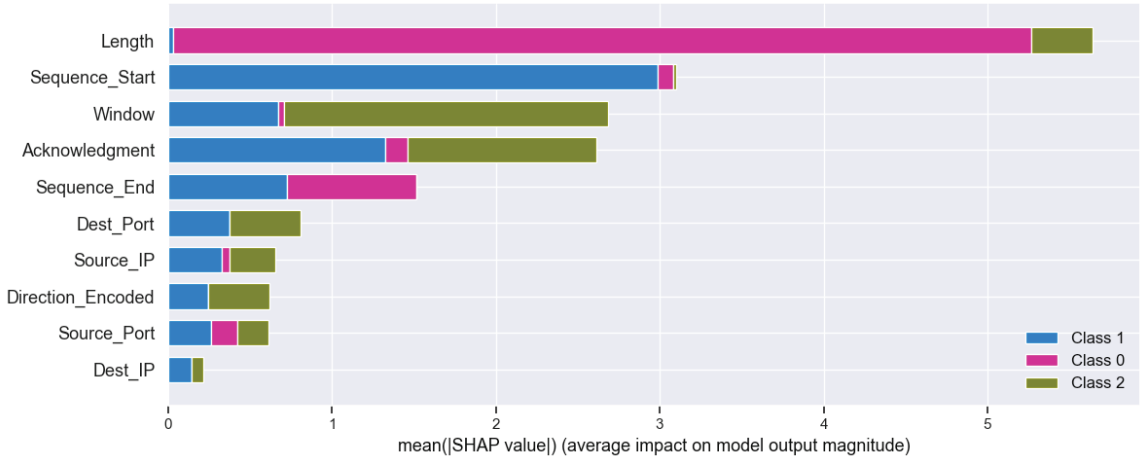


Figure 50.SHAP Analysis for Perimeter Based System

Class 0:

The ‘"Length" feature is a strong indicator for identifying instances belonging to Class 0. This implies that the length of specific data points or sequences is crucial in determining their classification as Class 0. Furthermore, the "Sequence End" feature offers some support but to a lesser extent compared to the "Length" feature.

Class 1:

Features other than "Length" appears to be more effective in identifying instances belonging to Class 1. This suggests that although the length of data points may not provide as much information for distinguishing Class 1, other features like "Window," "Acknowledgement," and "Dest_Port" hold more significance in classifying instances into Class 1.

Class 2:

The feature known as "Window" has the greatest influence on identifying instances that belong to Class 2. Additionally, the features "Acknowledgement" and "Dest_Port" also contribute to classifying Class 2 instances. This implies that specific characteristics related to networks, potentially associated with data packets or connections, play a crucial role in distinguishing Class 2 from the other classes.

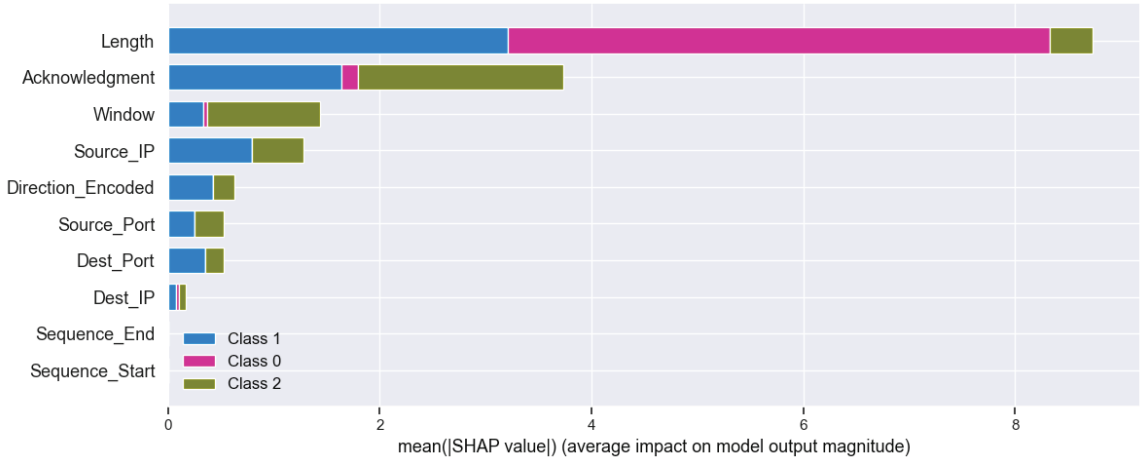


Figure 51. SHAP Analysis for ZTA Based System

In comparison to the Perimeter-based system, the ZTA-based system exhibits a greater impact in terms of "Length" when its value surpasses 8, whereas the Perimeter-based system only surpasses 5. Additionally, there is a difference in the hierarchy of impactful variables; sequence start no longer ranks as the second most influential factor in SHAP values.

Class 0:

The "Length" column is excellent for identifying instances in Class 0, similar to the Perimeter-Based System. This indicates that the length of specific data points or sequences is vital in determining their classification as Class 0. Additionally, the

"Sequence End" feature offers some support in identifying Class 0, albeit not to the same extent as the "Length" feature.

Class 1:

In this case, "Length" emerges as the crucial factor in classifying class 1. Each feature provided in the dataset significantly contributes to the classification of class 1, which distinguishes it from the Perimeter System Based method.

Class 2:

The "Acknowledgement" feature has the greatest impact on identifying instances that belong to Class 2. Additionally, the "Window" and "Source_IP" features also contribute to classifying Class 2 instances.

4.15 Summary

The adoption of Zero Trust Architecture has had a positive influence on the network or system, resulting in a significant reduction in security vulnerabilities and unauthorized access. By analyzing data from both the Perimeter security-based and the ZTA security-based systems, it is evident that the security controls within ZTA offer superior protection for PII data. This chapter focuses on analyzing these data sources to construct predictive models that further validate the effectiveness of ZTA's security measures. Additionally, it is suggested that enhancements can be made to improve anomaly detection capabilities within ZTA's threat intelligence function for better detection of novel attacks.

The analysis of tcpdump data files from both systems, using Time Series, indicates that ZTA can further enhance security controls in both systems. However, statistically speaking, the ZTA security-based system performed better compared to the Perimeter

security-based system. The analysis also suggests that the implementation of ZTA may have influenced the patterns of response sizes observed in the post-scanned log files. To fully assess its impact on the system, it is crucial to understand how exactly ZTA has affected data interactions and response sizes.

Furthermore, during the post-ZTA implementation phase, it was observed that there is a lower number of log entries containing HTTP POST requests compared to the pre-ZTA implementation phase. This suggests that ZTA might have had an impact on the frequency of POST requests within the network or system. The decrease in POST requests is a positive outcome and could indicate a reduction in potentially risky data submissions or unauthorized actions.

Here are specific findings noted in this chapter:

- When the ZTA function is applied, the error status significantly decreases (from 80% to approximately 60%), and the percentage of successful code increases by over 10%. Based on these findings, implementing ZTA can aid in reducing error statuses in the logs. Such errors may be caused by unauthorized access to applications and systems.
- Among the three algorithms utilized in our model, XGBoost demonstrates superior performance with a 99% accuracy rate for anomaly activity identification within the system.

Chapter 5. Discussion and Conclusions

5.1 Discussion

Remote work and hybrid work locations and the adoption of cloud services have become prevalent in contemporary corporations. Nowadays, many employees view these setups as crucial perks provided by employers to attract top talent. In fact, some workers are even willing to leave a position that lacks hybrid options but provides higher pay in favor of a job that offers a hybrid arrangement at a lower salary. However, it is vital to acknowledge that the integration of hybrid work and cloud-based solutions has also heightened the susceptibility of corporations to cybersecurity incidents.

Fortunately, an exciting solution known as Zero Trust Architecture (ZTA) has shown great potential in replacing traditional security practices and providing better protection against ransomware and data breaches.

To test the hypotheses, this praxis leveraged the data from the systems created specifically to conduct this study. The data consisted of simulated attacks against the systems captured and analyzed to test ZTA and perimeter security's ability to detect and prevent cybersecurity attacks. The results were then compared to identify which security approach performs better in attack discovery and prevention. This information was used to analyze the three hypotheses designed for this praxis:

H1: The perimeter security model is less effective at preventing cyber threats to cloud workloads and remote connectivity.

H2: The ZTA security model protects PII data more effectively than perimeter-based security.

H3: Adding anomaly detection features improves ZTA detection capabilities.

The results of the analysis demonstrate that ZTA is a superior security architecture for addressing the unique challenges posed by cloud workloads and hybrid working environments. Using ZTA shows can help organizations achieve the security of PII data and prevent ransomware attacks. This praxis accomplished all the research objectives introduced in Section 1.5.

5.2 Conclusions

This research has shown that the implementation of Zero Trust Architecture (ZTA) in corporate networks can prevent data breaches and ransomware attacks or significantly reduce their impact. With the ongoing trend of hybrid workers and digital transformation, it becomes crucial for modern enterprises to have robust security controls in place to manage risks effectively. The machine learning model developed in this study can assist organizations in addressing the risk factors mentioned in Hypothesis 2 and Hypothesis 3, thereby enhancing their security posture, safeguarding Personally Identifiable Information (PII) data, and ensuring compliance with privacy regulations. In addition, this research demonstrated that tcpdump data can be useful in slightly enhancing the anomaly detection function in ZTA.

The XGBoost algorithm outperforms the other algorithms in this study. The anomaly detection results (Table 6) for both ZTA and Perimeter systems were consistently better than those of the other algorithms. However, when comparing the performance before and after applying the ZTA function to the training dataset, there was no significant improvement in anomaly detection capabilities for either system. This

suggests that both systems' detection capabilities will improve with this enhancement, but not significantly.

Table 12. Models Performance Summary

Models for Anomaly Detection					
Perimeter Based Security System	**Algorithm**	**Accuracy**	**Precision**	**Recall**	**F-Measure**
	Logistic Regression	95%	.69	.96	.69
	Random Forest	98%	.71	.98	.73
	XGBoost	**99%**	**.64**	**.88**	**.78**
ZTA Based Security System	Logistic Regression	96%	.69	.97	.70
	Random Forest	96%	.69	.97	.70
	XGBoost	**99%**	**.78**	**.89**	**.81**

Due to the simplicity of the single instance architecture used to validate hypotheses in this study, it is recognized that there may be issues with the precision of the analysis conducted. This is because it does not provide options to test different types of parameter intrusions, which could skew the results. As mentioned earlier (**Table 12**), XGBoost outperformed other models regarding Accuracy and F-Measures. However, its Precision and Recall results were less interesting than those of other models used in this experiment. This can directly be attributed to the simplicity of the architecture employed for running these tests.

However, we can still conclude, based on the overall results, we can still conclude that:

H1: The perimeter security model is less effective at preventing cyber threats to cloud workloads and remote connectivity.

H2: The ZTA security model protects PII data more effectively than perimeter-based security.

H3: Adding anomaly detection features improves ZTA detection capabilities.

5.3 Contributions to Body of Knowledge

This praxis made several contributions to the body of knowledge in the field of data security:

- This study is the first of its kind to conduct a comparative analysis between Zero Trust Architecture (ZTA) and Perimeter security. Karabacak & Whittaker (2022) conducted a comparative analysis that did not incorporate machine learning or any attack simulations against ZTA. Instead, their research focused on comparing the MITRE ATT&CK framework with advanced persistent Threat (PTA) techniques and ZTA security controls. To conduct this study, a machine learning model was utilized. The model was trained using data from both ZTA and Perimeter security deployments. The dataset included various features such as the type of ZTA deployment, the type of Perimeter security deployment, and performance metrics for each deployment. The objective of training this model was to predict the relative performance of a ZTA deployment compared to a Perimeter security deployment. Additionally, the machine learning model was employed to forecast the likelihood of a data breach occurring under each deployment type. By using a machine learning model, organizations can make informed decisions about which security model fits their needs.
- To address modern cybersecurity challenges most organizations face, this research found that ZTA offers better security controls compared to the

effectiveness of the perimeter security model. For instance, the praxis validated that security vulnerabilities were not visible by security scanning tools, which impacts the ability of an attacker to discover vulnerabilities that can be exploited. On the other hand, those vulnerabilities were discoverable in the Perimeter security environment.

- This praxis also found that the threat intelligence within ZTA can be slightly improved by using an anomaly detection function. Although the improvement is not statically pronounced, it will allow ZTA to use a predictive model to identify novel attacks. However, due to limited research time, the praxis could not statistically establish if the improvement was significant enough to warrant its implementation into ZTA's threat intelligence feature. The issue of data overfitting also noted in the study, hampered the full analysis of this capability.

5.4 Recommendations for Future Research

One of the main challenges currently encountered by zero trust and micro-segmentation tools is their complexity, coupled with a lack of user-friendly administration and policy design/implementation. To effectively assist organizations in implementing zero trust, it is imperative for enterprise-class technologies to offer an intuitive console and policy engine. Additionally, well-designed reporting and metrics, effortless installation and monitoring for endpoint and workload agents, as well as robust support for multiple technologies and platforms (particularly cloud environments) are crucial requirements. (ZPE Systems, 2021).

Another concern raised in research regarding ZTA is the potential resource overhead. This study did not examine whether dynamic access control and trust

evaluation can lead to significant performance degradation. In the ZTA deployment used in this study, no noticeable decrease in performance was observed compared to perimeter security measures. However, it should be noted that this deployment was less complex than what might be found in a typical corporate network.

The literature also discusses the scalability of ZTA across companies of all sizes and its manageability in complex environments. This study concluded that ZTA is still a concept in its early stages of development, making its deployment challenging. Not many technology companies have an easy approach to implementing it during its infancy, making adoption quite difficult.

The research was conducted on a single-instance architecture (Figure 16) configured in Amazon Web Services (AWS). However, an extensive and complex architecture to validate these hypotheses and obtain more accurate research results is recommended for future research.

References

Adrian, T., & Ferreira, C. (2023, March 2). Mounting cyber threats mean financial firms urgently need better safeguards. *International Monetary Fund.* https://www.imf.org/en/Blogs/Articles/2023/03/02/mounting-cyber-threats-mean-financial-firms-urgently-need-better-safeguards (Accessed: September 28, 2023)

Akhtar, S., Sheorey, P. A., & Bhattacharya, S. (2021). Cyber security solutions for businesses in financial services: Challenges, opportunities, and the way forward. *International Journal of Business Intelligence Research, 12*(1), 82-97. https:// doi: 10.4018/IJBIR.20210101.oa5

Alsaqour, R., Majrashi, A., Alreedi, M., Alomar, K., & Abdelhaq, M. (2021). Defense in depth: Multilayer of security. *International Journal of Communication Networks and Information Security*, *13*(2), 242-248.

Apruzzese, G., Laskov, P., Montes de Oca, E., Mallouli, W., Brdalo Rapa, L., Grammatopoulos, A. V., & Di Franco, F. (2023). The role of machine learning in cybersecurity. *Digital Threats: Research and Practice*, *4*(1), 1-38. https://dl.acm.org/doi/full/10.1145/3545574

Awan, A. A. (2023, September 20). Hands-on with unsupervised learning: K-means clustering. *KD nuggets.* https://www.kdnuggets.com/handson-with-unsupervised-learning-kmeans-clustering (Accessed: 26 September 2023)

Bajracharya, A., Harvey B. &Rawat D. B. (2023). *Recent advances in cybersecurity and fraud detection in financial services: A survey*. [Conference presentation]. IEEE 13th Annual Computing and Communication Workshop and Conference (CCWC), Las Vegas, NV, USA, 0368-0374. https://ieeexplore.ieee.org/abstract/document/10099355

Benito, R., Shaffer, A., & Singh, G. (2023, February). An automated post-exploitation model for cyber red teaming. Proceeding of the 18th International Conference on Cyber Warfare and Security, 18(1) 25-34. doi:https://doi.org/10.34190/iccws.18.1.978

Borkovich, D. J., & Skovira, R. J. (2020). Working from home: Cybersecurity in the age of COVID-19. *Issues in Information Systems, 21*(4), 234-246.

Canam Research (2021, January 1). Financial Services Cybersecurity Survey 2021 - Trend Report. *Fortinet.* https://www.fortinet.com/content/dam/fortinet/assets/reports/financial-services-cybersecurity-survey-trend-report.pdf (Accessed: 14 January 2023)

Chauhan, P. S., & Kshetri, N. (2023). Ransomware as a service kit: A novel cybercrime strategy to monetize victims' data. *Computer, 56*(10), 102-106. doi:10.1109/MC.2023.3298072

CISA (2023, April 1). Zero Trust Maturity Model. *Cyber Security and Infrastructure Security Agency*. https://www.cisa.gov/sites/default/files/2023-04/zero_trust_maturity_model_v2_508.pdf (Accessed: 24 June 2023)

David. (2019, August 16). Machine learning in network traffi*c*. *Amazonaws.com*. https://rstudio-pubs-static.s3.amazonaws.com/522841_7daf696454f749079458eef118fb2f66.html (28 September 2023)

Department of Energy. (2006, May). Control systems cyber security: Defense in depth strategies (External Report # INL/EXT-06-11478). U.S. Department of Homeland Security. https://www.energy.gov/sites/prod/files/oeprod/DocumentsandMedia/Defense_in_Depth_Strategies.pdf

Deshpande, A. (2021). Analyzing the deployment of Zero Trust Network Architecture in enterprise networks.*GIS Science Journal, 8*(5), 1586-1594. https://www.researchgate.net/

Eddolls, T. (2022, September 14). The costs of data breaches in 2022. *Techchannel.* https://techchannel.com/Enterprise/09/2022/data-breaches-2022 (Accessed: January 24, 2023)

Flashpoint (2022, December 20). Flashpoint year in review: 2022 financial threat landscape. *Flashpoint*. https://flashpoint.io/blog/risk-intelligence-year-in-review-financial/#:~:text=KEY%20TAKEAWAYs&text=The%20financial%20sector%20experienced%20the,to%20ATM%20skimmers%20in%202022. (Accessed: 24 June 2023)

Hummer, M., Kunz, M., Netter, M., Fuchs, L. & Pernul G. (2016). Adaptive identity and access management—contextual data based policies. *EURASIP Journal on Information Security, 19*(1). DOI 10.1186/s13635-016-0043-2

IBM (n.d.). What is random forest? *IBM*. https://www.ibm.com/topics/random-forest#:~:text=Random%20forest%20is%20a%20commonly,both%20classification%20and%20regression%20problems. (Accessed: 28 September 2023)

ITRC (2022, October 1). ITRC business impact report. *ITRC Identity Theft Resource Center*. https://www.idtheftcenter.org/wp-content/uploads/2022/10/2022-Business-Impact-Report_V2.3_Final_Linked.pdf (Accessed: 24 January 2023)

Kapustin, V., & Paulauskas, N. (2023). Analysis of TCP flood attack using NetFlow. *Mokslas–Lietuvos ateitis/Science–Future of Lithuania*, *15*. https://doi.org/10.3846/mla.2023.18847

Kavish111. (2022, May 30). Handling imbalanced data with imbalance-learn in Python. *Analytics Vidhiya.* https://www.analyticsvidhya.com/blog/2022/05/handling-imbalanced-data-with-imbalance-learn-in-python/? (Accessed: 28 September 2023)

Karabacak, B., & Whittaker, T. (2022, March 17-18.). Zero Trust and advanced persistent threats: Who will win the war? *17th International Conference on Cyber Warfare and Security*, 17(1),92-101. https://doi.org/10.34190/iccws.17.1.10

Kazdagli, M., Tiwari, M., & Kumar, A. (2022). Using constraint programming and graph representation learning for generating interpretable cloud security policies. *arXiv preprint arXiv:2205.01240*. https://doi.org/10.48550/arXiv.2205.01240

Kennedy, A. (2022, March 21). Adaptive trust: Zero Trust Architecture in a financial services environment. *BPI.* https://bpi.com/adaptive-trust-zero-trust-architecture-in-a-financial-services-environment/

Kim, B., Alawami M. A., Kim, E., Oh, S., Park, J., & Kim, H. (2023). A comparative study of time series anomaly detection models for industrial control systems. *Sensors; 23*(3):1310. https://doi.org/10.3390/s23031310

Levine, A., & Tucker, B. (2023). Zero Trust Architecture: Risk discussion. *Digital Threats: Research and Practice, 4*(1), 1-6. https://doi.org/10.1145/3573892

Nassif, A. B., Talib, M. A., Nasir, Q., & Dakalbab, F. M. (2021). Machine learning for anomaly detection: A systematic review. *IEEE Access, 9*, 78658-78700. doi: 10.1109/ACCESS.2021.3083060.

Nemirovsky, D. (2023, September 8). Fortifying the foundation: Empowering a Zero Trust security paradigm. *Security Boulevard*. https://securityboulevard.com/2023/09/fortifying-the-foundation-empowering-a-zero-trust-security-paradigm/?

Omar, S., Ngadi, A., & Jebur, H. H. (2013). Machine learning techniques for anomaly detection: An overview. *International Journal of Computer Applications, 79*(2), 33-41. https://citeseerx.ist.psu.edu/document?repid=rep1&type=pdf&doi=0278bbaf1db5df036f02393679d485260b1daeb7

Orman, H. (2003).The Morris worm: A fifteen-year perspective. *IEEE Security & Privacy,1*(5) 35-43. doi: 10.1109/MSECP.2003.1236233.

Puthiyavan, U. (2023). *Design and deploy a secure azure environment* (1st ed.). APress. https://link.springer.com/book/10.1007/978-1-4842-9678-3

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020, August). Zero trust architecture. National Institute of Standards and Technology (NIST SP 800–207). https://doi.org/10.6028/NIST.SP.800-207

Sarkar, S., Choudhary, G., Shandilya, S. K., Hussain, A., & Kim, H. (2022). Security of zero trust networks in cloud computing: A comparative review. *Sustainability, 14*(18), 11213. https://www.mdpi.com/2071-1050/14/18/11213

Singh, S. (2023, May 23). LightGBM (Light Gradient Boosting Machine). *Geeksforgeeks*. https://www.geeksforgeeks.org/lightgbm-light-gradient-boosting-machine/ (Accessed: 28 September 2023)

Syed, N. F., Shah, S. W., Shaghaghi, A., Anwar, A., Baig, Z., & Doss, R. (2022). Zero trust architecture (ZTA): A comprehensive survey. *IEEE Access, 10*, 57143-57179. doi: 10.1109/ACCESS.2022.3174679.

Teerakanok, S., Uehara, T., & Inomata, A. (2021). Migrating to Zero Trust Architecture: Reviews and challenges. *Security and Communication Networks, 2021*, 1-10. https://doi.org/10.1155/2021/9947347

Verma, N. (2022, September 7). XGBoost Algorithm Explained in Less Than 5 Minutes. *Medium.com*. https://medium.com/@techynilesh/xgboost-algorithm-explained-in-less-than-5-minutes-b561dcc1ccee#:~:text=XGBoost%20works%20by%20training%20a,improvement%20on%20the%20GBM%20algorithm.

Ward, R., & Beyer, B. (2014, December). Beyondcorp: A new approach to enterprise security. *Usenix, 39*(6), 6-11. https://www.usenix.org/system/files/login/articles/login_dec14_02_ward.pdf

Wylde, A. (2021, June). Zero trust: Never trust, always verify. *2021 International Conference on Cyber Situational Awareness, Data Analytics and Assessment (CyberSA)*, Dublin, Ireland, 1-4.. https://doi.org/10.1109/CyberSA52016.2021.9478244

Zaharia, A. V. (2020). Security risks of cloud and mobile technologies during the pandemic and their opportunities. *Informatica Economica, 24*(3), 64-74. https://revistaie.ase.ro/content/95/06%20-%20zaharia.pdf

ZPE. (2021, January 25). How to overcome 5 challenges of Zero Trust Security. *ZPE Systems, Inc.*. https://zpesystems.com/how-to-overcome-5-challenges-of-zero-trust-security/ (Accessed: 24 June 2023)

Awan, A. A. (2023, June 1). *An Introduction to SHAP Values and Machine Learning Interpretability*. Https://www.Datacamp.com/. Retrieved October 18, 2023, from https://www.datacamp.com/tutorial/introduction-to-shap-values-machine-learning-interpretability#

Appendix A

GitHub Repository for Praxis Source code and model results:

https://github.com/munuoja/praxis